



Introduction à la cyber-sécurité

La sécurité en informatique

Sommaire

1. WEB

- 1.1. Qu'est-ce que le Web ?
- 1.2. Objectifs du chapitre
- 1.3. Challenge 1 : Inspecteur et code source
 - 1.3.1. Comprendre et utiliser l'inspecteur de page
- 1.4. Challenge 2 : Mot de passe
- 1.5. Challenge 3 : Mr. Robot
- 1.6. Challenge 4 : URL Secrète
 - 1.6.1. Les paramètres d'URL
 - 1.6.2. Votre mission
 - 1.6.3. Aspect sécurité
- 1.7. Challenge 5 : Styliste de la page
 - 1.7.1. Étapes à suivre :
- 1.8. Challenge 6 XSS Alert
- 1.9. Challenge 7 Pour aller plus loin...
- 1.10. Récapitulatif
- 1.11. Glossaire

2. RÉSEAU

- 2.1. Introduction
- 2.2. Mise en contexte
- 2.3. Objectifs du chapitre
 - 2.3.1. Préparez votre laboratoire d'analyse 
 - 2.3.1.1. Installation de Wireshark
 - 2.3.1.2. Installation de Npcap (Crucial !)
 - 2.3.2. Les bases du protocole Web
 - 2.3.2.1. HTTP (Hypertext Transfer Protocol)
 - 2.3.2.2. HTTPS (Hypertext Transfer Protocol Secure)
- 2.4. Mission n°1 : Analyse de trafic HTTP non sécurisé
 - 2.4.1. Analyse de la capture réseau
 - 2.4.2. Structure de l'interface Wireshark
 - 2.4.3. Astuce pour l'analyse
- 2.5. Mission n°2 : Analyse d'un formulaire bancaire compromis
 - 2.5.0.1. Le protocole HTTP POST et l'envoi de formulaires
- 2.6. Mission n°3 : Déchiffrement de trafic HTTPS
 - 2.6.1. Théorie sur le déchiffrement TLS
 - 2.6.2. Analyse de la capture réseau
- 2.7. Mission n°4 : Analyse d'une connexion FTP compromise
 - 2.7.1. Qu'est-ce que le protocole FTP ?
 - 2.7.2. Votre Objectif
 - 2.7.3. Analyse de la capture réseau
- 2.8. Mission n°5 : Analyse d'une machine compromise
 - 2.8.1. Analyse du trafic réseau
 - 2.8.1.1. Étape 1 : Identification du serveur de commande et contrôle (C2)
 - 2.8.1.2. Étape 2 : Identification du payload malveillant
- 2.9. Et les VPN dans tout ça ?
- 2.10. Récapitulatif

3. STÉGANOGRAPHIE

- 3.1. Introduction
 - 3.1.1. L'Art de Cacher l'Invisible
- 3.2. Objectifs du chapitre
 - 3.2.1. Concept et Applications
 - 3.2.2. Supports et Techniques
 - 3.2.3. Outils et Méthodes
- 3.3. Challenge 1 Carré blanc sur fond blanc
 - 3.3.1. Étapes à suivre :
- 3.4. Challenge 2 Linux > Windows
 - 3.4.0.1. Comprendre les Métadonnées d'une Image
 - 3.4.0.2. Outils pour visualiser les métadonnées
 - 3.4.0.3. Méthodologie pour ce challenge
- 3.5. Challenge 3 La NSA
- 3.6. Challenge 4 La plus belle ville du monde
- 3.7. Challenge 5 Pilule bleu, pilule rouge
- 3.8. Challenge 6 Gulfstream
- 3.9. Challenge 7 Pour aller plus loin...
- 3.10. Récapitulatif
- 3.11. Glossaire

4. CRYPTOGRAPHIE

- 4.1. Introduction
- 4.2. Objectifs du chapitre
- 4.3. Challenge 1 : Irréductible gaulois
- 4.4. Challenge 2 Capitale de la gastronomie
- 4.5. Challenge 3 Louis XIV
- 4.6. Challenge 4 Combinaison
- 4.7. Challenge 5 Alpha Wann
- 4.8. Challenge 7 Pour aller plus loin...
- 4.9. Récapitulatif
- 4.10. Glossaire

5. MISC

- 5.1. Objectifs du chapitre
- 5.2. QRcode
- 5.3. Houston
- 5.4. Three
- 5.5. GeoINT
- 5.6. Voiture sportive
- 5.7. Michael Jordan
- 5.8. Asia
- 5.9. Mariokart reverse
- 5.10. Challenge 7 Pour aller plus loin...
- 5.11. Récapitulatif

6. Conclusion

- 6.1. Pour aller plus loin

Introduction

Bienvenue dans le monde fascinant de la cybersécurité ! Ce domaine peut sembler un peu technique au début, mais vous verrez rapidement que les attaques les plus marquantes ne sont pas toujours les plus compliquées.

Avertissement

Les techniques présentées dans ce projet sont à des fins pédagogiques uniquement. Ne tentez en aucun cas de les reproduire sur des systèmes qui ne vous appartiennent pas ou sans autorisation explicite.

Un peu d'histoire...

Le Système d'information (SI)

Un système d'information est un ensemble organisé de ressources (matériel, logiciel, personnel, données, procédures) permettant d'acquérir, de traiter, de stocker et de communiquer de l'information dans une organisation. La cybersécurité intervient sur l'ensemble du SI, on parle souvent de CIA.... non ce n'est pas l'agence de renseignement Américaine :

- Confidentialité
- Intégrité
- Disponibilité (Availability)

Lorsqu'on parle de cyberattaque, les objectifs principaux des attaquants sont de compromettre la confidentialité, l'intégrité ou la disponibilité des systèmes et des données. Les entreprises et organisations doivent donc mettre en place des mesures de sécurité adaptées pour se protéger contre ces menaces.

Les Hackers, qui sont-ils ?

Il est souvent difficile de remonter avec certitude l'origine d'une cyberattaque. On appelle cela dans le jargon l'imputation (attribution). Les motivations des attaquants sont multiples :

- Argent
- Espionnage
- Déstabilisation

Les groupes cybercriminels, surtout ceux qui sont liés à des États, sont souvent désignés par des noms de code pour les différencier et suivre leurs activités. C'est un peu comme donner un surnom à des gangs pour les reconnaître plus facilement. Cependant, il n'y a pas qu'une seule façon de les nommer. Les grandes entreprises de cybersécurité ont chacune leur propre système, et c'est là que ça devient amusant ! Chez Microsoft, on utilise des noms de catastrophes naturelles. L'idée est de refléter la force de la nature, imprévisible et souvent dévastatrice, comme une attaque cybercriminelle :

Blizzard  Russia	Typhoon  China	Sandstorm  Iran	Sleet  North Korea	Dust  Türkiye	Gale  Germany	Derecho  Spain
Cyclone  Vietnam	Rain  Lebanon	Hail  South Korea	Whirlwind  Pakistan	Squall  Singapore	Haze  Syria	Frost  Ukraine
Monsoon  India	Flood  Influence operations	Storm  Groups in development	Tempest  Financially motivated	Tsunami  Private sector offensive actor	Lightning  Palestinian Authority	Tornado  United States

Chez CrowdStrike, on préfère le règne animal pour les groupes cybercriminels étatiques :

Adversary	Category or Nation-State
 BEAR	Russian Federation
 CHOLLIMA	Democratic People's Republic of Korea (North Korea)
 JACKAL	Hacktivist
 KITTEN	Iran
 LEOPARD	Pakistan
 PANDA	People's Republic of China
 SPIDER	eCrime
 TIGER	India

L'objectif de cette semaine est de vous faire découvrir les bases de la cybersécurité via plusieurs challenges regroupés en 5 catégories : web / réseau / Stégano / crypto et misc. La catégorie misc englobe tous les challenges ne s'incluant pas dans les 4 précédentes et peuvent être réalisés si vous avez terminé le chapitre plus tôt que prévu.

Flag

Dans tous les challenges, vous allez devoir rechercher ce qu'on appelle un « flag* » (drapeau en anglais). Dans les challenges de cybersécurité, c'est une pratique courante ; si vous en réalisez davantage à l'avenir, cela sera souvent le cas. Aujourd'hui, le format du flag sera :

```
FLAG{xxxxxxxx}
```

Entre les accolades, il y aura souvent des mots ou une phrase liés aux challenges. Par exemple, pour un challenge dont l'objectif est de trouver un mot de passe, le flag serait :

```
FLAG{MOT_DE_PASSE_SECRET}
```

Documents

Important

Des "assets" (fichiers utiles) ont été préparés pour vous, **téléchargez les avant de commencer votre aventure ici** : <https://github.com/SUPINFO-Organization/ressources-stages/raw/refs/heads/main/cyber-5.zip>.

1. WEB

1. WEB

1.1. Qu'est-ce que le Web ?

Avant de se plonger dans les challenges, comprenons d'abord ce qu'est le "web" ! Vous l'utilisez tous les jours, mais savez-vous vraiment ce que c'est ?



Le Web, ou plus précisément le **World Wide Web** (WWW), c'est comme une immense toile d'araignée mondiale. C'est un système de documents interconnectés accessibles via Internet. Internet, c'est le réseau physique (les câbles, les routeurs...), et le Web, c'est l'information qui y circule.

Imaginez une bibliothèque géante. Internet, c'est le bâtiment, les étagères, et les chemins entre les étagères. Le Web, ce sont tous les livres, magazines et documents que vous trouvez dans cette bibliothèque, reliés entre eux par des renvois. Comment ça marche, très simplement ?

Quand vous tapez une adresse comme google.com dans votre navigateur, voici ce qui se passe en quelques secondes :

1. Votre ordinateur (le client) envoie une demande via Internet.
2. Cette demande arrive à un autre ordinateur, un serveur web, qui stocke le site google.com.
3. Le serveur web "sert" (envoie) la page web à votre ordinateur.
4. Votre navigateur (Chrome, Firefox, Safari) reçoit le code de la page et le transforme en ce que vous voyez à l'écran : du texte, des images, des vidéos.

C'est ce processus simple qui nous permet de consulter des milliards de pages web, de regarder des vidéos, de jouer en ligne, ou d'envoyer des messages instantanés !

1.2. Objectifs du chapitre

À la fin de cette journée, vous serez capable de :

1. Utiliser les outils de développement du navigateur pour inspecter et analyser le code source d'une page web
2. Comprendre et manipuler les paramètres d'URL pour accéder à des fonctionnalités cachées
3. Explorer et interpréter le fichier robots.txt pour découvrir des ressources cachées
4. Modifier les styles CSS pour révéler des éléments masqués
5. Comprendre les bases des failles XSS et leur exploitation
6. Appliquer des bonnes pratiques de sécurité web pour protéger les informations sensibles

Ces compétences constituent les fondamentaux de la sécurité web et vous permettront de mieux comprendre comment les sites web fonctionnent et comment les protéger.

1.3. Challenge 1 : Inspecteur et code source

Assets: web/Chall1/index.html

Information

Les sites internet peuvent être développés dans de nombreux langages de programmation, mais quel que soit le langage utilisé, trois types de fichiers principaux sont créés et utilisés par votre navigateur pour afficher la page : les fichiers HTML (HyperText Markup Language), CSS (Cascading Style Sheets) et JS (JavaScript).

Information

Pour vous permettre de découvrir la cybersécurité, nous avons préparé des sites web que vous trouverez dans le dossier web accompagnant ce sujet.

Le saviez-vous ? Vous pouvez double-cliquer sur un fichier .html pour l'ouvrir directement dans votre navigateur et afficher la page web.

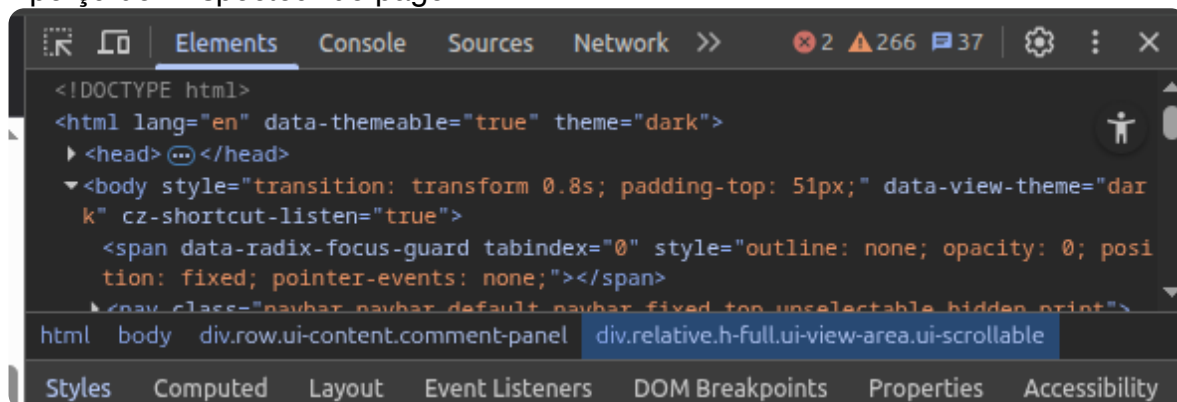
Pour ce premier défi, vous allez devenir de véritables détectives ! Une page web est bien plus qu'une simple image à l'écran. Votre navigateur (Chrome, Firefox, Edge...) est un outil puissant qui vous permet de voir ce qui se cache derrière la page visible, comme son code source, les scripts qui la font fonctionner, ou encore son apparence (les styles).

Ce puissant outil disponible dans votre navigateur se nomme **l'inspecteur de pages**.

1.3.1. Comprendre et utiliser l'inspecteur de page

Pour ouvrir l'inspecteur de page, vous pouvez utiliser le raccourci `FN + F12` ou faire un clic droit sur une page web et sélectionner `Inspecter`.

Aperçu de l'inspecteur de page :



L'inspecteur de page dispose de différents onglets qui permettent chacun de voir différentes informations sur la page web actuelle :

- **Elements** : Permet de voir la structure HTML (code) de la page affichée.
- **Console** : Permet de voir les logs (messages d'informations envoyés lors de l'utilisation de la page).
- **Sources** : Permet de voir les fichiers reçus par votre navigateur et utilisés pour afficher la page web.
- **Network** : Permet de voir les appels réseau (informations envoyées et reçues par internet) lors de l'utilisation de la page web.
- **Performance** : Permet de voir les délais de chargement et d'actions lors de l'utilisation de la page web.
- **Application** : Permet de voir les différentes informations enregistrées par votre navigateur (comme les fameux cookies) lors de votre utilisation.

Astuce

Si vous ne voyez pas tous les onglets dans votre inspecteur, vous pouvez cliquer sur l'icône  pour tout afficher.

Vous pouvez fermer votre inspecteur en cliquant sur l'icône  en haut à droite.

Votre mission : Commencez par ouvrir la page web associée à ce défi (web/Chall1/index.html) en double-cliquant sur le fichier .html. Utilisez l'inspecteur de page de votre navigateur. Cherchez bien, le flag se cache peut-être quelque part !

1.4. Challenge 2 : Mot de passe

Assets: Chall2/index.html

Ce deuxième challenge vous demande d'être très observateur. Lisez attentivement tout le contenu de la page. Une information cruciale est cachée quelque part et vous permettra de révéler le flag.

En cybersécurité, vous devez souvent combiner votre sens de l'observation, votre logique et vos compétences techniques. Les oublis et négligences rendent souvent la tâche plus facile aux attaquants. Un mot de passe oublié ou un mot de passe par défaut non modifié sont des erreurs courantes qui permettent aux attaquants d'atteindre leurs objectifs. À vous de jouer dans ce challenge !

Astuce

Pour trouver rapidement une information sur une page, utilisez le raccourci clavier Ctrl + F (ou Cmd + F sur Mac).

Information

Observez bien : cette page est-elle vraiment identique à la première ?

Information

Une fois que vous avez trouvé le mot de passe, cliquez sur ce bouton :



1.5. Challenge 3 : Mr. Robot

Assets: Chall3/index.html

Dans notre monde numérique actuel, les robots (aussi appelés "bots" ou "crawlers") parcourent constamment Internet. Ces programmes automatisés, qu'il s'agisse d'intelligences artificielles collectant des données, de bots cartographiant le web, ou de moteurs de recherche comme Google ou Ecosia, s'appuient tous sur un fichier particulier qui contient des informations cruciales pour leur fonctionnement. Votre mission : trouver ce fichier qui sera la clé du challenge.

Information

Le fichier `robots.txt` est un document texte placé à la racine (à la source) d'un site web qui donne des instructions aux robots d'indexation des moteurs de recherche. Il permet aux webmasters de contrôler l'accès des robots à certaines parties de leur site.

Avant de commencer le challenge, je vous invite à visiter les sites suivants pour comprendre le concept :

- <https://www.google.com/robots.txt>
- <https://www.youtube.com/robots.txt>
- <https://www.leboncoin.fr/robots.txt>
- <https://www.tiktok.com/robots.txt>

Tous ces sites connus partagent un point commun : ils possèdent une page similaire avec des configurations différentes mais un objectif identique.

Cette page permet l'indexation sur Google. L'indexation consiste à analyser et stocker le contenu d'un site web ou d'un document dans une base de données ou un moteur de recherche, afin de pouvoir retrouver rapidement l'information lorsqu'un utilisateur effectue une recherche. Les moteurs de recherche les plus connus utilisent des "crawlers" (aussi appelés "spiders") qui commencent par consulter la page `robots.txt` pour déterminer quelles informations ils peuvent récupérer sur le site.

[!NOTE] > Exemple de contenu d'un fichier robots.txt :

```
1 User-agent: *
2 Disallow: /private/
3 Allow: /public/
```

Ce fichier indique que tous les robots (`User-agent: *`) ne doivent pas accéder au dossier `/private/` mais peuvent accéder au dossier `/public/`.

Vérifiez si notre site du challenge n°3 possède cette page. Pour cela, vous devrez ajouter `/robots.txt` à l'URL de base du site.

1.6. Challenge 4 : URL Secrète

Assets: Chall4/index.html

Dans ce challenge, vous allez découvrir comment les paramètres d'URL peuvent être utilisés pour contrôler le comportement d'une page web. Une URL (Uniform Resource Locator) est l'adresse unique qui permet d'identifier et d'accéder à une ressource spécifique sur Internet, comme une page web, une image ou un fichier.

1.6.1. Les paramètres d'URL

En informatique, un paramètre d'URL (aussi appelé "query parameter") est une variable utilisée pour transmettre des valeurs à une application web. Ces paramètres sont généralement séparés de l'URL principale par un point d'interrogation (?) et peuvent être multiples, séparés par desesperluettes (&).

Par exemple, dans une URL comme :

```
https://example.com/login?username=john&password=secret
```

- `username=john` et `password=secret` sont des paramètres d'URL
- Le point d'interrogation (?) indique le début des paramètres
- L'esperluette (&) sépare les différents paramètres

1.6.2. Votre mission

Pour commencer ce challenge, cliquez sur le bouton suivant :



Vous remarquerez que l'URL change et qu'un paramètre est ajouté :

```
/chall%204/index.html?secret=false
```

Votre objectif est de modifier ce paramètre pour accéder au contenu caché. En changeant la valeur du paramètre de "vrai" à "faux" (en informatique "true" à "false"), vous pourrez afficher la page secrète.

1.6.3. Aspect sécurité

Cette manipulation d'URL est une technique basique, mais elle illustre un concept important en sécurité web : la manipulation de paramètres. Dans un contexte plus avancé, cette technique pourrait être utilisée pour des attaques plus sophistiquées, comme l'injection de chemins de fichiers :

```
index.html?secret=../../etc/passwd
```

Le fichier `/etc/passwd` contient les informations de base des utilisateurs sur un système Unix/Linux. Sur un serveur mal configuré, cette manipulation pourrait permettre d'accéder à ces informations sensibles, constituant ainsi une faille de sécurité critique connue sous le nom de "Path Traversal" ou "Directory Traversal".

1.7. Challenge 5 : Styliste de la page

Assets: Chall5/index.html

Pour ce challenge, vous allez devoir utiliser la fonctionnalité "inspecter l'élément" de votre navigateur, comme lors du premier challenge. Cette fois-ci, vous devrez explorer plus en profondeur le code source pour découvrir des éléments que le créateur du site a intentionnellement masqués.

Information

Le CSS (Cascading Style Sheets) est un langage de style qui définit la présentation visuelle des pages web. Il permet de contrôler les couleurs, les tailles, les polices de caractères, les marges, et bien d'autres aspects visuels. Sans CSS, les pages web seraient très basiques et uniformes, utilisant uniquement le style par défaut du navigateur.

Information

En CSS, la propriété `display` contrôle comment un élément est affiché dans la page :

- `display: block` : L'élément s'affiche comme un bloc, occupant toute la largeur disponible et créant un saut de ligne avant et après.
- `display: none` : L'élément est complètement masqué et ne prend aucun espace dans la mise en page. C'est comme s'il n'existait pas dans le rendu visuel de la page.

Gardez ces concepts à l'esprit, ils seront essentiels pour résoudre ce challenge.

1.7.1. Étapes à suivre :

1. Ouvrez les outils de développement de votre navigateur en appuyant sur F12 ou en faisant un clic droit et en sélectionnant "Inspecter l'élément".

2. Dans l'inspecteur, recherchez la section qui regroupe tous les "services" de la page.

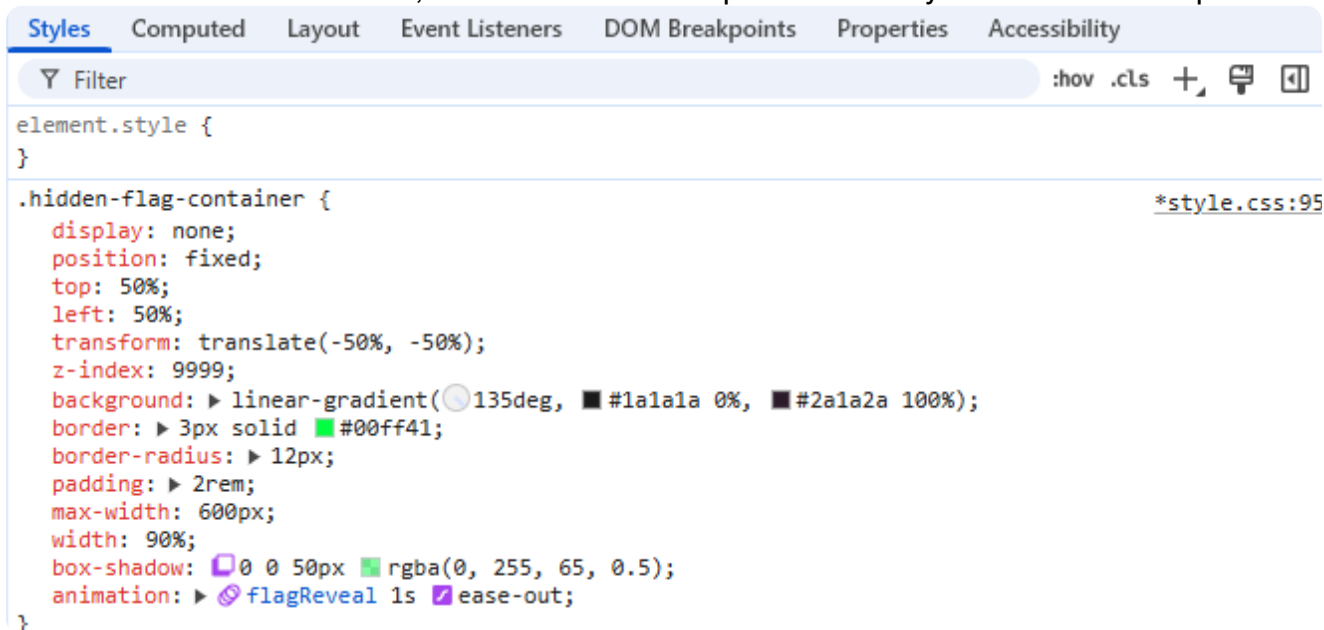
```
<section id="services" class="services">...</section> == $0
```

3. Cliquez sur la petite flèche à gauche de la section pour développer l'arborescence et voir tous les services.

4. Recherchez l'élément "hidden flag" dans la structure HTML.

```
<div id="hidden-flag" class="hidden-flag-container">...</div>
```

5. En sélectionnant cet élément, vous accédez à son panneau de styles CSS dans l'inspecteur.



6. Vous remarquerez que la première propriété CSS est `display: none`, ce qui explique pourquoi le flag est invisible sur la page.

7. Pour révéler le flag, tentez de cliquer sur `none` et entrez une valeur différente.

Information

Cette technique de masquage d'éléments avec `display: none` est couramment utilisée en développement web pour cacher temporairement du contenu. Cependant, comme vous venez de le découvrir, ce n'est pas une méthode sécurisée pour protéger des informations sensibles, car n'importe qui peut facilement modifier les styles CSS dans son navigateur.

1.8. Challenge 6 XSS Alert

Assets: Chall6/index.html

Pour ce challenge, vous allez devoir exploiter une faille XSS (Cross-Site Scripting). Une faille XSS est une vulnérabilité de sécurité qui permet à un attaquant d'injecter du code malveillant, généralement du JavaScript, dans une page web consultée par d'autres utilisateurs. Cette vulnérabilité peut conduire au vol de données, à la manipulation du site ou à d'autres actions malveillantes.

[!NOTE] > **Théorie sur les failles XSS** : Il existe trois types principaux de failles XSS :

1. **XSS Réfléchi (Reflected)** : Le code malveillant est inclus dans l'URL et est exécuté immédiatement.
2. **XSS Stocké (Stored)** : Le code malveillant est stocké dans la base de données et s'exécute à chaque chargement de la page.
3. **XSS basé sur le DOM** : Le code malveillant modifie la structure du DOM sans passer par le serveur.

Dans ce challenge, nous utilisons une approche simplifiée pour comprendre le concept de base des failles XSS.

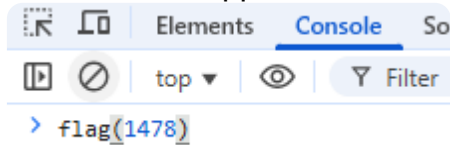
Pour résoudre ce challenge, vous devrez utiliser la console du navigateur. La console du navigateur est un outil intégré qui permet de visualiser, déboguer et interagir avec le code JavaScript, CSS et HTML d'une page web en temps réel.

Dans le code source de la page, vous pouvez observer une fonction JavaScript. En programmation, une fonction est un bloc de code réutilisable qui réalise une tâche précise :

```
function flag(a) {  
    if (a === 1234) {  
        alert("You solved this challenge, Congratz ! Send a screen  
an organizer to get the flag !");  
    }  
}
```

L'analyse du code révèle que le nombre "1234" est nécessaire pour valider le challenge.

Pour valider le challenge, vous devez appeler la fonction `flag()` avec le bon paramètre dans la



console du navigateur :

1.9. Challenge 7 Pour aller plus loin...

Assets: Chall7/matrix.zip

Pour venir à bout de ce challenge bonus, vous allez devoir utiliser toutes les choses apprises aujourd'hui.

Saurez-vous entrer dans la matrice ?

A screenshot of a web application interface for a challenge named 'MATRIX'. The interface has a black background with a green border. At the top, the word 'MATRIX' is displayed in large, bold, green capital letters. Below it, the text 'Entrez le flag pour valider le challenge.' is written in a green monospace font. Underneath this text is a green rectangular input field containing the placeholder text 'FLAG{...}'. At the bottom center of the interface is a green rectangular button with the word 'VALIDER' in black capital letters.

MATRIX

Entrez le flag pour valider le challenge.

FLAG{...}

VALIDER

1.10. Récapitulatif

Félicitations ! Vous avez découvert les bases de la sécurité web à travers plusieurs challenges :

1. Inspection du code source

- Utilisation de l'inspecteur de page (F12)
- Analyse du code HTML, CSS et JavaScript
- Découverte d'informations cachées dans le code source

2. Manipulation des paramètres d'URL

- Compréhension de la structure des URLs
- Modification des paramètres GET
- Découverte de fonctionnalités cachées

3. Analyse des métadonnées

- Exploration du fichier robots.txt
- Compréhension de son rôle dans l'indexation
- Découverte de ressources cachées

4. Bonnes pratiques de sécurité

- Ne jamais stocker d'informations sensibles en clair dans le code source
- Utiliser HTTPS pour sécuriser les communications
- Protéger les ressources sensibles via robots.txt
- Ne pas se fier uniquement au masquage visuel (display: none)
- Valider et sécuriser les paramètres d'URL

5. Outils et techniques

- Utilisation de l'inspecteur de page
- Manipulation des styles CSS
- Analyse des requêtes HTTP
- Découverte de fichiers cachés

Ces connaissances constituent une base solide pour comprendre les vulnérabilités web courantes et se protéger !

1.11. Glossaire

- **URL** (Uniform Resource Locator) : Adresse unique qui permet d'identifier et d'accéder à une ressource spécifique sur Internet (site web, page, image, etc.). Une URL se compose généralement d'un protocole (http/https), d'un nom de domaine et d'un chemin.
- **Console** : Interface textuelle permettant d'interagir avec un système informatique en saisissant des commandes. Dans le contexte du web, la console du navigateur permet de déboguer et d'exécuter du code JavaScript.
- **Fonction** : Bloc de code réutilisable qui exécute une tâche spécifique. Une fonction peut recevoir des paramètres en entrée et retourner un résultat. Elle permet d'organiser le code de manière modulaire et d'éviter la répétition.
- **Flag** : Chaîne de caractères qui valide un challenge de cybersécurité (drapeau en anglais). Dans les CTF (Capture The Flag), le format est généralement `FLAG{texte}`. Le flag prouve que le challenge a été résolu.
- **Bot** : Application logicielle automatisée qui exécute des tâches répétitives sur un réseau. Les bots peuvent être légitimes (moteurs de recherche, assistants virtuels) ou malveillants (spam, attaques DDoS).
- **Paramètre** : Valeur ou donnée fournie à une fonction, une méthode ou un programme pour influencer son comportement ou sa sortie. Les paramètres permettent de rendre le code plus flexible et réutilisable.
- **CSS** (Cascading Style Sheets) : Langage de style utilisé pour décrire la présentation visuelle des pages web. Il permet de contrôler les couleurs, les polices, les marges, les animations et d'autres aspects visuels. Le CSS fonctionne en cascade, où les styles peuvent être hérités et surchargés.



2. RÉSEAU

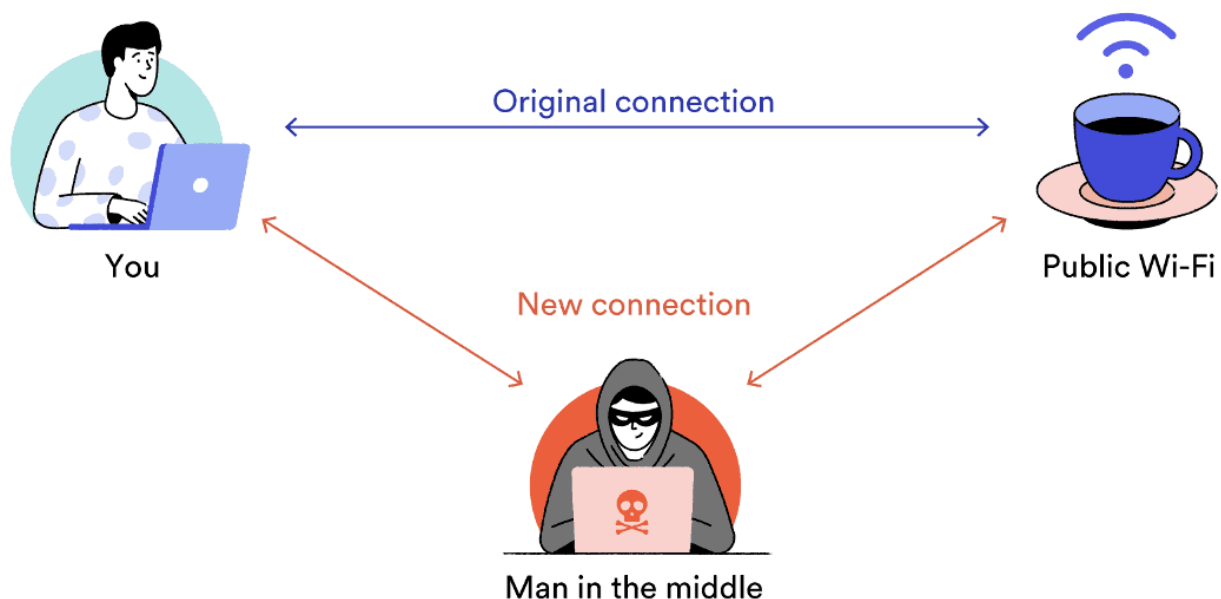
2. RÉSEAU

2.1. Introduction

L'objectif de ce chapitre est de vous faire découvrir le domaine du réseau informatique. La maîtrise des bases du réseau est fondamentale pour évoluer dans la cybersécurité. Un ordinateur isolé (air-gapped) est effectivement plus sûr car il ne peut pas être directement exposé aux menaces extérieures. Cependant, dès qu'un appareil se connecte à Internet, il devient potentiellement vulnérable aux attaques. Cette exposition, bien que risquée, est nécessaire pour comprendre et maîtriser les mécanismes de sécurité.

2.2. Mise en contexte

Imaginez-vous dans un restaurant McDonald's, profitant d'une connexion WiFi publique tout en consultant vos réseaux sociaux. Dans ce scénario, un attaquant malveillant est connecté au même réseau et utilise des outils d'analyse pour intercepter le trafic non sécurisé.



Votre mission aujourd'hui est de vous transformer en cyber-enquêteur pour analyser des captures de ce réseau et découvrir ce que le pirate a bien pu manigancer.

2.3. Objectifs du chapitre

À la fin de ce chapitre, vous serez capable de :

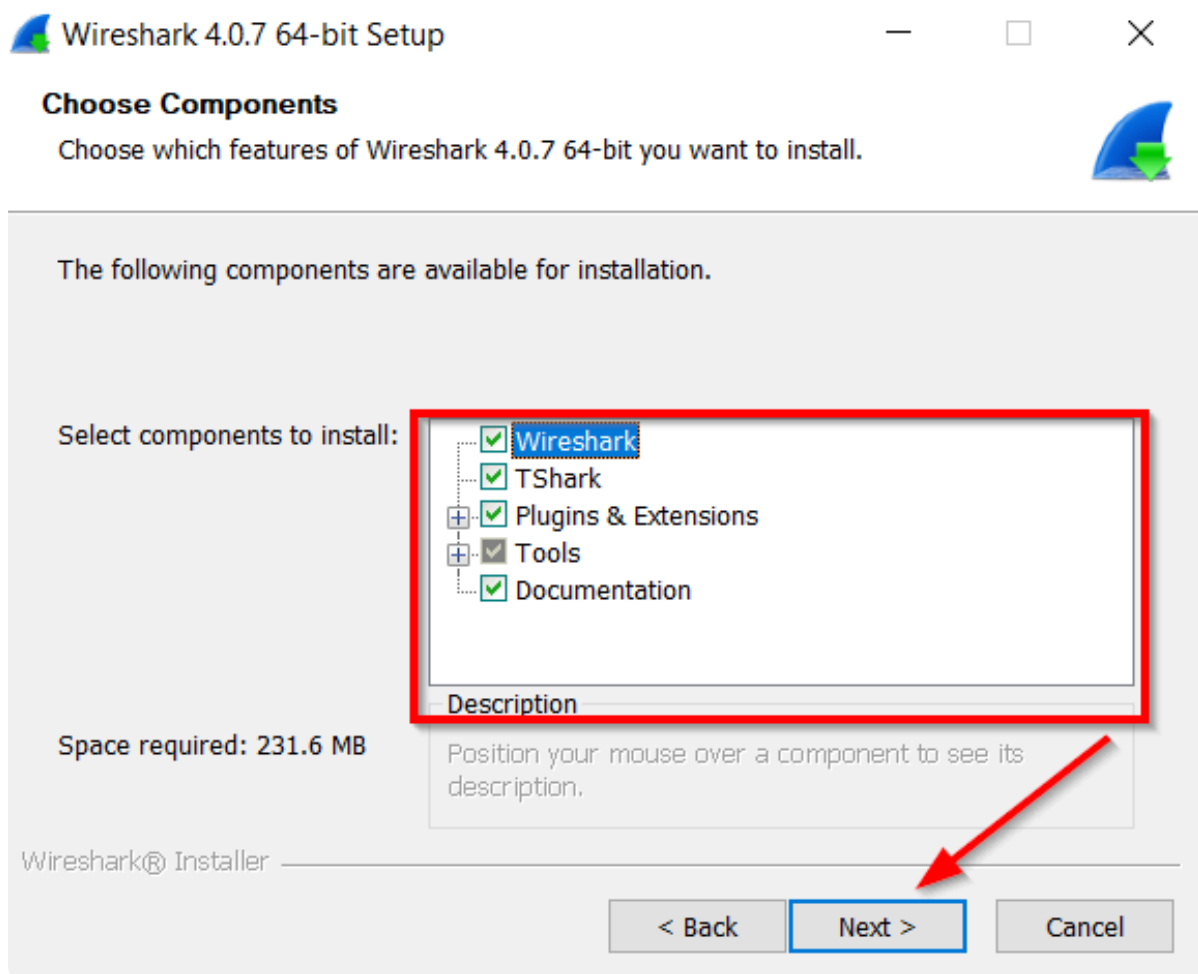
1. Utiliser Wireshark pour capturer et analyser le trafic réseau
2. Comprendre la différence entre les protocoles HTTP et HTTPS
3. Identifier et analyser les vulnérabilités dans les communications non sécurisées
4. Décoder le trafic chiffré TLS/SSL avec les clés appropriées
5. Analyser les connexions FTP et identifier les informations sensibles exposées
6. Détecter et analyser les comportements malveillants sur un réseau
7. Comprendre l'importance des VPN et des bonnes pratiques de sécurité réseau

2.3.1. Préparez votre laboratoire d'analyse

Pour écouter ces conversations réseau, il nous faut un outil spécial.

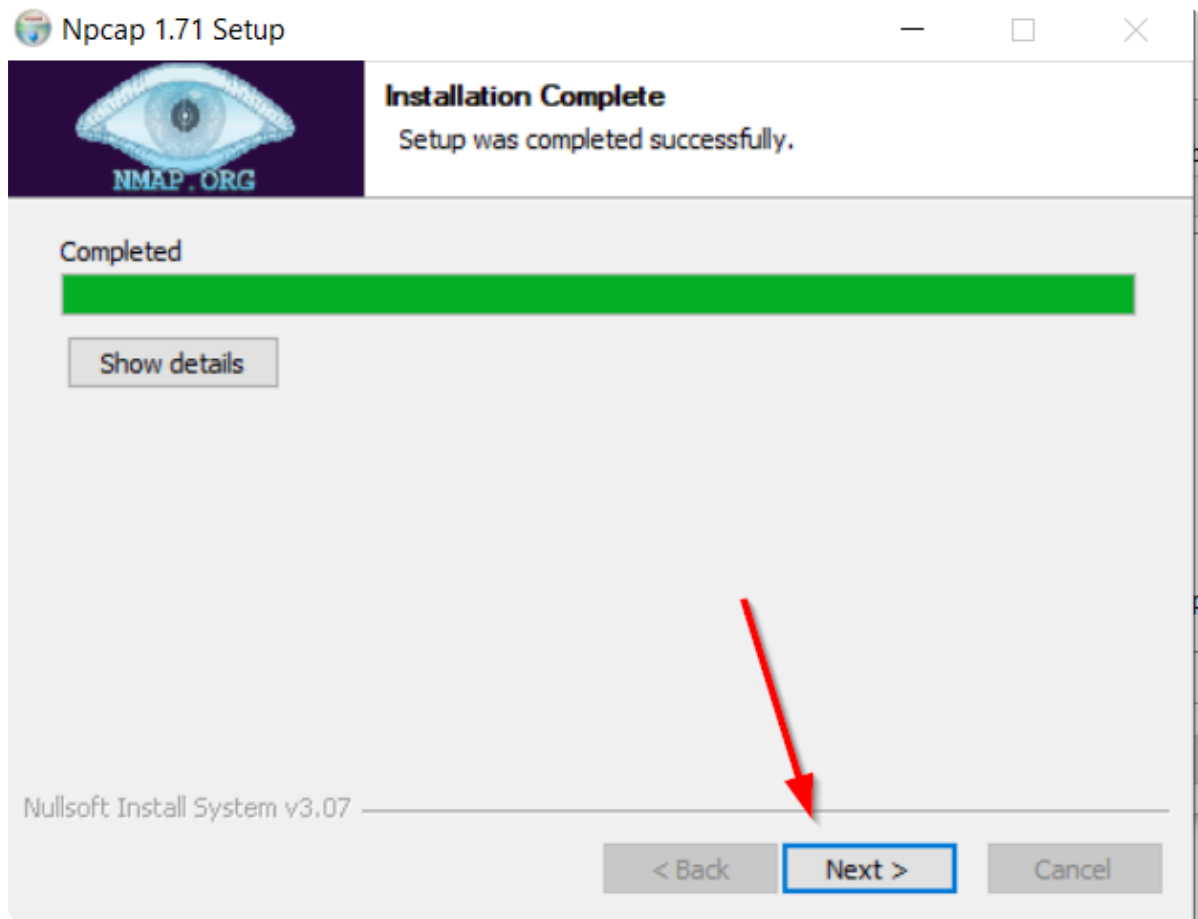
2.3.1.1. Installation de Wireshark

- Téléchargez et installez Wireshark : c'est l'outil n°1 des analystes réseau. Il permet de visualiser en détail tout le trafic réseau.
 - Rendez-vous sur le site de téléchargement et choisissez la version adaptée à votre système d'exploitation (Windows ou macOS).
 - Lancez l'installateur. Conservez les options de composants par défaut pour une installation complète.



2.3.1.2. Installation de Npcap (Crucial !)

- L'installateur vous proposera d'installer Npcap (ou WinPcap sur les anciennes versions). C'est le "microphone" de Wireshark, le pilote qui lui donne la permission d'écouter votre carte réseau.
 - Acceptez impérativement l'installation de Npcap ! Sans lui, Wireshark ne pourra pas capturer de trafic. Conservez les options de Npcap par défaut.



Une fois l'installation terminée, lancez Wireshark pour vérifier que tout fonctionne correctement. Vous êtes maintenant prêt pour l'enquête !

2.3.2. Les bases du protocole Web

La clé de votre mission réside dans la compréhension de la différence entre HTTP et HTTPS :

2.3.2.1. HTTP (Hypertext Transfer Protocol)

- C'est le protocole de base du web
- Présente une faille majeure : toutes les données échangées (identifiants, mots de passe, etc.) sont envoyées en clair, sans aucun chiffrement
- Analogie : comme envoyer une carte postale - tout le monde peut lire le message
- Un attaquant peut facilement intercepter et lire ces informations

2.3.2.2. HTTPS (Hypertext Transfer Protocol Secure)

- Version sécurisée du HTTP
- Le "S" indique l'utilisation du chiffrement SSL/TLS
- Toutes les données sont chiffrées avant d'être transmises
- Même si un pirate intercepte les paquets, il ne verra qu'un charabia illisible
- Analogie : comme envoyer une lettre dans une enveloppe scellée avec une clé - seuls l'expéditeur et le destinataire peuvent la déchiffrer

Information

Point théorique intéressant : Le chiffrement SSL/TLS utilise un système de clés asymétriques :

- Une clé publique pour chiffrer les données
- Une clé privée pour les déchiffrer
- Un certificat numérique pour authentifier l'identité du serveur

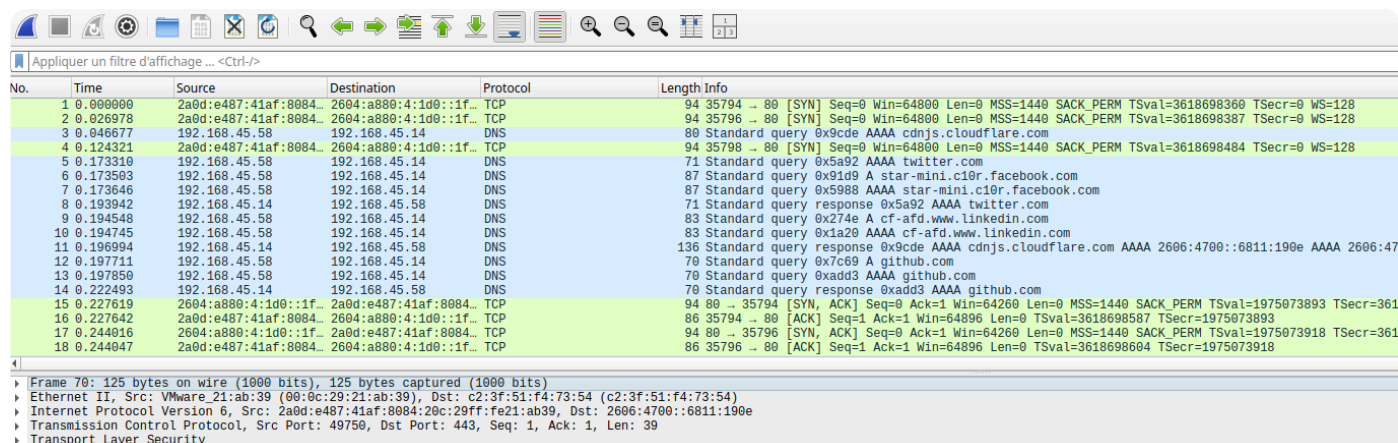
2.4. Mission n°1 : Analyse de trafic HTTP non sécurisé

Un client peu méfiant se connecte à son ancien blog personnel pour publier un article. Malheureusement pour lui, son site n'a jamais été mis à jour et n'utilise pas le protocole sécurisé HTTPS. Pour notre hacker, c'est une véritable aubaine !

Votre Objectif : Analyser la capture réseau pour identifier l'URL du site consulté.

2.4.1. Analyse de la capture réseau

Pour cette mission, vous devez télécharger le fichier `httpforever.pcap`. Une fois ouvert dans Wireshark, vous verrez des centaines de lignes qui peuvent sembler complexes. Pas de panique, c'est normal ! Chaque ligne représente un "paquet", c'est-à-dire un petit morceau de la conversation réseau.



No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	2a0d:e487:41af:8084::	2604:a880:4:1d0::1f...	TCP	94	35794 → 80 [SYN] Seq=0 Win=64800 Len=0 MSS=1440 SACK_PERM TSval=3618698360 TSecr=0 WS=128
2	0.026978	2a0d:e487:41af:8084::	2604:a880:4:1d0::1f...	TCP	94	35796 → 80 [SYN] Seq=0 Win=64800 Len=0 MSS=1440 SACK_PERM TSval=3618698387 TSecr=0 WS=128
3	0.046677	192.168.45.58	192.168.45.14	DNS	80	Standard query 0x9cde AAAA cdnjs.cloudflare.com
4	0.124321	2a0d:e487:41af:8084::	2604:a880:4:1d0::1f...	TCP	94	35798 → 80 [SYN] Seq=0 Win=64800 Len=0 MSS=1440 SACK_PERM TSval=3618698484 TSecr=0 WS=128
5	0.173310	192.168.45.58	192.168.45.14	DNS	71	Standard query 0x5a92 AAAA twitter.com
6	0.173503	192.168.45.58	192.168.45.14	DNS	87	Standard query 0x91d9 A star-mini.c10r.facebook.com
7	0.173646	192.168.45.58	192.168.45.14	DNS	87	Standard query 0x5988 AAAA star-mini.c10r.facebook.com
8	0.193942	192.168.45.14	192.168.45.58	DNS	71	Standard query response 0x5a92 AAAA twitter.com
9	0.194548	192.168.45.58	192.168.45.14	DNS	83	Standard query 0x274e A cf-afd.www.linkedin.com
10	0.194745	192.168.45.58	192.168.45.14	DNS	83	Standard query 0x1a20 AAAA cf-afd.www.linkedin.com
11	0.196994	192.168.45.14	192.168.45.58	DNS	136	Standard query response 0x9cde AAAA cdnjs.cloudflare.com AAAA 2606:4700::6811:190e AAAA 2606:4700::6811:190e
12	0.197711	192.168.45.58	192.168.45.14	DNS	70	Standard query 0x7c69 A github.com
13	0.197850	192.168.45.58	192.168.45.14	DNS	70	Standard query 0xad03 AAAA github.com
14	0.222493	192.168.45.14	192.168.45.58	DNS	70	Standard query response 0xad03 AAAA github.com
15	0.227619	2604:a880:4:1d0::1f...	2a0d:e487:41af:8084::	TCP	94	80 → 35794 [SYN, ACK] Seq=0 Ack=1 Win=64260 Len=0 MSS=1440 SACK_PERM TSval=1975073893 TSecr=3618698360
16	0.227642	2a0d:e487:41af:8084::	2604:a880:4:1d0::1f...	TCP	86	35794 → 80 [ACK] Seq=1 Ack=1 Win=64896 Len=0 TSval=3618698587 TSecr=1975073893
17	0.244016	2604:a880:4:1d0::1f...	2a0d:e487:41af:8084::	TCP	94	80 → 35796 [SYN, ACK] Seq=0 Ack=1 Win=64260 Len=0 MSS=1440 SACK_PERM TSval=1975073918 TSecr=3618698604
18	0.244047	2a0d:e487:41af:8084::	2604:a880:4:1d0::1f...	TCP	86	35796 → 80 [ACK] Seq=1 Ack=1 Win=64896 Len=0 TSval=3618698604 TSecr=1975073918

Frame 70: 125 bytes on wire (1000 bits), 125 bytes captured (1000 bits) on interface 0
Ethernet II, Src: VMware_21:ab:39 (00:0c:29:21:ab:39), Dst: c2:3f:51:f4:73:54 (c2:3f:51:f4:73:54)
Internet Protocol Version 6, Src: 2a0d:e487:41af:8084::, Dst: 2606:4700::6811:190e
Transmission Control Protocol, Src Port: 49750, Dst Port: 443, Seq: 1, Ack: 1, Len: 39
Transport Layer Security

2.4.2. Structure de l'interface Wireshark

Voici les principales colonnes et informations que vous verrez dans l'interface de Wireshark :

- 1 **No.** : Le numéro d'ordre du paquet dans la capture.
- 2 **Time** : L'heure à laquelle le paquet a été capturé, relative au début de la capture.
- 3 **Source** : L'adresse IP ou le nom d'hôte de l'expéditeur du paquet.
- 4 **Destination** : L'adresse IP ou le nom d'hôte du destinataire du paquet.
- 5 **Protocol** : Le protocole utilisé par le paquet (ex: TCP, UDP, HTTP, DNS, etc.).
- 6 **Length** : La taille du paquet en octets.
- 7 **Info** : Une description sommaire du contenu du paquet, souvent très utile pour identifier rapidement ce qui se passe.

2.4.3. Astuce pour l'analyse

Pour faciliter votre recherche, utilisez le filtre `http` dans la barre de recherche de Wireshark. Ce filtre vous permettra de ne voir que le trafic HTTP non sécurisé, ce qui vous aidera à identifier plus facilement l'URL du site consulté.

⚠ Attention

En cybersécurité, l'analyse de trafic réseau est une compétence fondamentale. Elle permet de détecter des activités suspectes, d'identifier des vulnérabilités et de comprendre le comportement des applications sur le réseau.

2.5. Mission n°2 : Analyse d'un formulaire bancaire compromis

Après avoir repéré le blog non sécurisé, le pirate a également intercepté une navigation vers un formulaire de recours bancaire peu fiable. Un client du McDonald's a envoyé des informations sensibles à sa banque tout en étant connecté au réseau WiFi public.

2.5.0.1. Le protocole HTTP POST et l'envoi de formulaires

Lorsque vous remplissez un formulaire sur un site web (formulaire de contact, de connexion ou, dans notre cas, un formulaire bancaire), les données saisies sont généralement envoyées au serveur web via une requête HTTP POST.

Les méthodes HTTP principales :

- **HTTP GET** : Utilisée pour demander des ressources (pages web, images, etc.). Les données sont visibles dans l'URL, ce qui les rend facilement observables.
- **HTTP POST** : Conçue pour envoyer des données importantes au serveur. Les données sont incluses dans le corps de la requête HTTP, ce qui les rend moins visibles dans l'URL. C'est la méthode privilégiée pour l'envoi d'informations confidentielles.

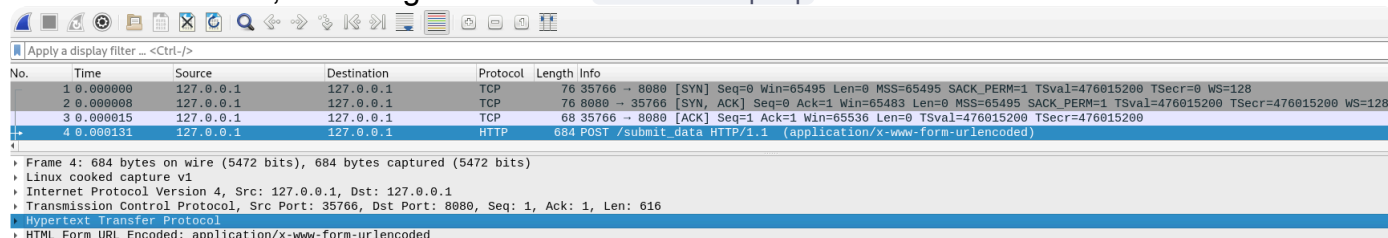
Avertissement

Vulnérabilité critique :

Le problème survient lorsque la requête HTTP POST n'est pas sécurisée par HTTPS. Si un site utilise simplement HTTP, même si les données ne sont pas dans l'URL, elles sont envoyées en clair dans le corps de la requête. Un attaquant interceptant le trafic peut alors lire le contenu du formulaire comme s'il s'agissait d'un texte simple.

Votre Objectif : Analyser la capture réseau pour retrouver le message que la victime a envoyé via le formulaire.

Pour cette mission, téléchargez le fichier `evilforms.pcap`.



Wireshark interface showing a packet capture of an HTTP POST request. The packet list shows a POST request from 127.0.0.1 to 127.0.0.1 on port 8080. The packet details pane shows the HTTP POST request with the body encoded as application/x-www-form-urlencoded.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	127.0.0.1	127.0.0.1	TCP	76	35766 → 8080 [SYN] Seq=0 Win=65495 Len=0 MSS=65495 SACK_PERM=1 TSval=476015200 TSecr=0 WS=128
2	0.000000	127.0.0.1	127.0.0.1	TCP	76	8080 → 35766 [SYN, ACK] Seq=0 Ack=1 Win=65483 Len=0 MSS=65495 SACK_PERM=1 TSval=476015200 TSecr=476015200 WS=128
3	0.000015	127.0.0.1	127.0.0.1	TCP	68	35766 → 8080 [ACK] Seq=1 Ack=1 Win=65536 Len=0 TSval=476015200 TSecr=476015200
4	0.000131	127.0.0.1	127.0.0.1	HTTP	684	POST /submit_data HTTP/1.1 (application/x-www-form-urlencoded)

Frame 4: 684 bytes on wire (5472 bits), 684 bytes captured (5472 bits)
Linux cooked capture v1
Internet Protocol Version 4, Src: 127.0.0.1, Dst: 127.0.0.1
Transmission Control Protocol, Src Port: 35766, Dst Port: 8080, Seq: 1, Ack: 1, Len: 616
Hypertext Transfer Protocol
HTML Form URL Encoded: application/x-www-form-urlencoded

Une fois le fichier ouvert dans Wireshark, suivez ces étapes pour analyser le trafic HTTP POST :

1. Filtrage du trafic :

- Utilisez le filtre `http.request.method == POST` pour ne voir que les requêtes POST
- Ou utilisez simplement `http.request` pour voir toutes les requêtes HTTP

2. Identification du paquet suspect :

- Recherchez le paquet HTTP correspondant à l'envoi du formulaire
- Ce paquet devrait contenir les données du formulaire

3. Analyse détaillée :

- Sélectionnez le paquet HTTP POST
- Dans le volet des détails du paquet (en bas de Wireshark), développez les sections liées au protocole HTTP
- Recherchez les sections suivantes :
 - `HTML Form URL-encoded`
 - `Line-based text`
 - `Form item`
- C'est dans ces sections que vous trouverez les données envoyées en clair

Information

Conseil d'analyse : Les données de formulaire sont généralement encodées en URL-encoded format. Par exemple, un espace est représenté par "%20" et un caractère spécial par son code hexadécimal correspondant.

2.6. Mission n°3 : Déchiffrement de trafic HTTPS

Un autre client, plus prudent, se connecte à un site sécurisé en HTTPS pour s'entraîner sur des challenges de cybersécurité. Le trafic est chiffré, le cadenas est bien présent. Normalement, le hacker ne devrait rien pouvoir lire.

Votre Objectif : Le hacker a été malin. Il a réussi à enregistrer les clés de session secrètes échangées sur le réseau du McDonald's au moment de la connexion du client. Vous allez utiliser sa clé volée pour déchiffrer la conversation et trouver le flag qu'il a validé.

2.6.1. Théorie sur le déchiffrement TLS

Le protocole TLS (Transport Layer Security) est la technologie qui sécurise les communications HTTPS. Il utilise un système de chiffrement asymétrique pour établir une connexion sécurisée :

1. Le client et le serveur échangent des clés publiques
2. Ils génèrent une clé de session symétrique (plus rapide pour le chiffrement)
3. Toute la communication est ensuite chiffrée avec cette clé de session

Si un attaquant intercepte les clés de session, il peut déchiffrer tout le trafic, même si la connexion est en HTTPS.

2.6.2. Analyse de la capture réseau

Téléchargez le fichier `rootme.pcap`. Une fois ouvert dans Wireshark, vous verrez ceci :

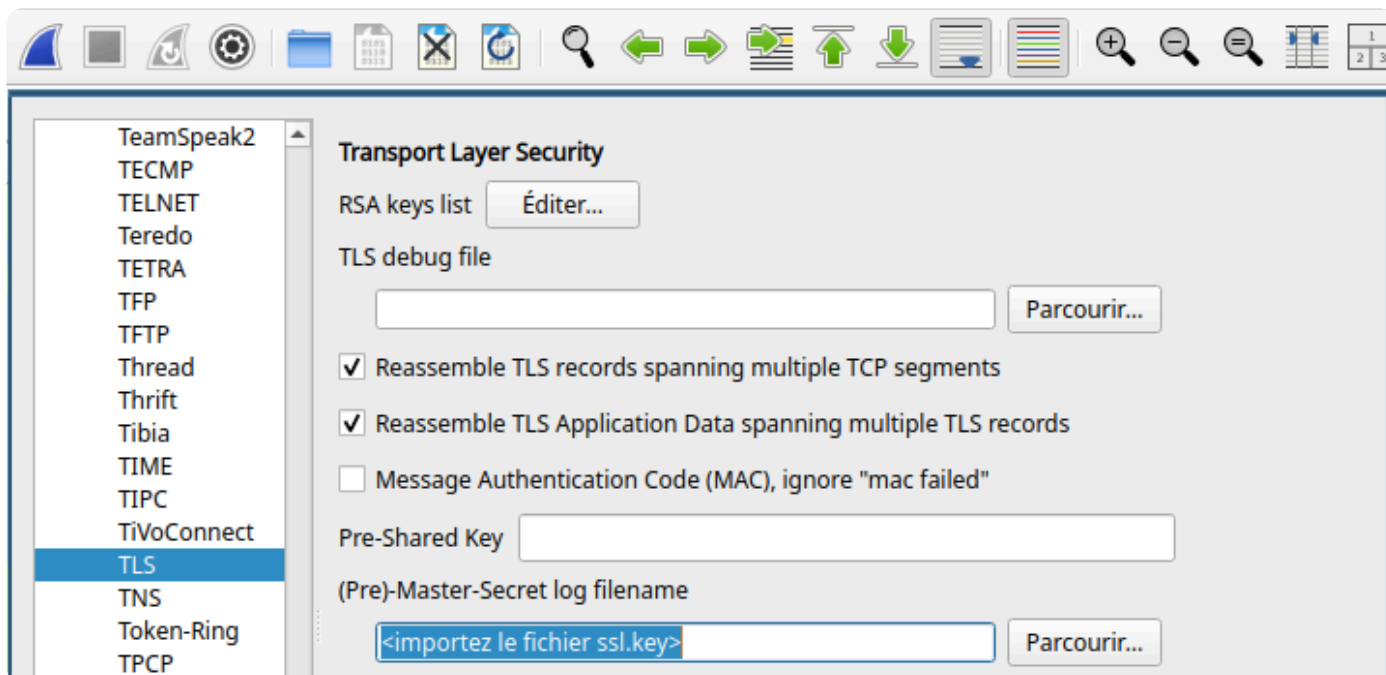


No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	192.168.45.58	212.129.28.16	TLSv1.3	583	Client Hello (SNI=www.root-me.org)
2	1.011663	212.129.28.16	192.168.45.58	TLSv1.3	304	Server Hello, Change Cipher Spec, Application Data, Application Data
3	1.012847	192.168.45.58	212.129.28.16	TLSv1.3	130	Change Cipher Spec, Application Data
4	1.013913	192.168.45.58	212.129.28.16	TLSv1.3	236	Application Data
5	1.014017	192.168.45.58	212.129.28.16	TLSv1.3	503	Application Data
6	1.600367	109.234.160.66	192.168.45.58	TLSv1.2	105	Application Data
7	1.600700	192.168.45.58	109.234.160.66	TLSv1.2	105	Application Data
8	1.600901	192.168.45.58	109.234.160.66	TLSv1.2	90	Application Data
9	1.604149	109.234.160.66	192.168.45.58	TLSv1.2	90	Application Data
10	1.812618	212.129.28.16	192.168.45.58	TLSv1.3	145	Application Data
11	1.820935	212.129.28.16	192.168.45.58	TLSv1.3	118	Application Data
12	1.821578	192.168.45.58	212.129.28.16	TLSv1.3	97	Application Data
13	1.918999	212.129.28.16	192.168.45.58	TLSv1.3	867	[TCP Previous segment not captured] , Continuation Data

C'est du trafic TLS (la technologie derrière HTTPS), complètement illisible. Mais vous avez la clé !

Plan d'attaque :

1. Téléchargez le fichier de clés `ssl.key`
2. Importez-le dans Wireshark en suivant le chemin : `Éditer > Préférences > Protocoles > TLS`
3. Cliquez sur **(Pre)-Master-Secret log filename** et sélectionnez le fichier **ssl.key** que vous venez de télécharger



Validez. Magie ! Le trafic TLS devrait se transformer en trafic HTTP lisible. ? Fouillez maintenant dans les paquets déchiffrés pour trouver le flag ! ?

Information

Cette technique de déchiffrement n'est possible que si l'attaquant a réussi à voler les clés de session. Dans une situation réelle, ces clés sont éphémères et changent régulièrement, rendant ce type d'attaque beaucoup plus difficile.

2.7. Mission n°4 : Analyse d'une connexion FTP compromise

Le hacker ne se contente pas d'écouter le trafic réseau. Il a repéré un ordinateur laissé déverrouillé pendant qu'un client est allé chercher sa commande. Profitant de cette opportunité, il tente de télécharger un malware depuis un serveur FTP.

2.7.1. Qu'est-ce que le protocole FTP ?

Le FTP (File Transfer Protocol) est un protocole de communication historique, spécifiquement conçu pour le transfert de fichiers entre un client et un serveur. Développé dans les années 1970, il présente aujourd'hui une vulnérabilité majeure : toutes les informations échangées, y compris :

- Les identifiants de connexion
- Les mots de passe
- Les noms de fichiers
- Le contenu des fichiers

sont transmises en clair (non chiffrées) sur le réseau. C'est comme parler à voix haute dans une bibliothèque pleine d'espions !

2.7.2. Votre Objectif

En tant qu'analyste en cybersécurité, vous devez espionner cette connexion FTP compromise pour découvrir :

1. Les identifiants (login/mot de passe) utilisés par le hacker
2. Le nom du fichier malveillant qu'il a tenté de télécharger

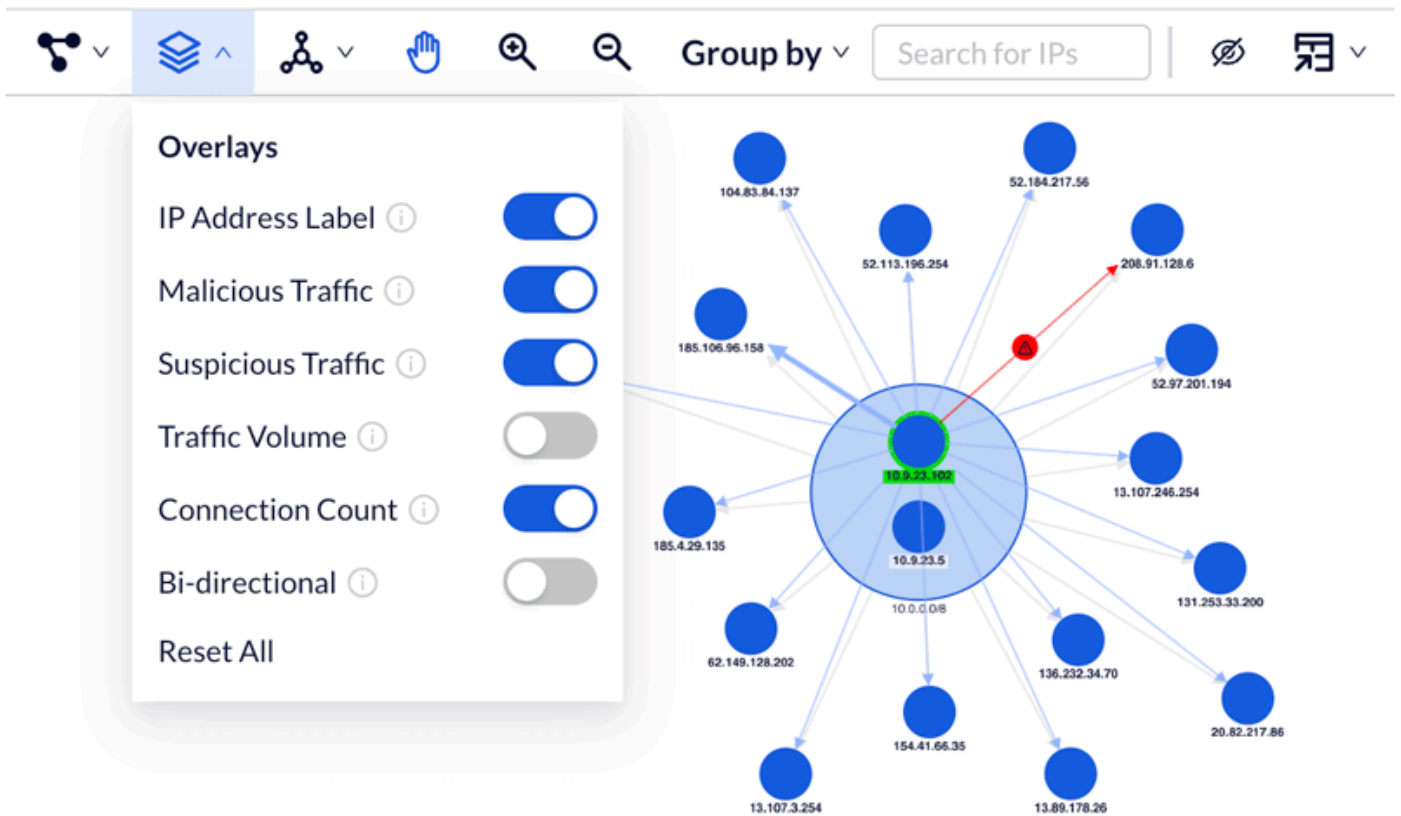
2.7.3. Analyse de la capture réseau

Téléchargez le fichier `notpetya.pcap` et ouvrez-le dans Wireshark. Pour faciliter votre analyse :

1. Utilisez le filtre `ftp` pour ne voir que le trafic FTP
2. Recherchez les commandes FTP standard :
 - `USER` : indique le nom d'utilisateur
 - `PASS` : contient le mot de passe
 - `RETR` : indique le fichier en cours de téléchargement

Astuce

En parallèle de Wireshark, vous pouvez utiliser PCAPviewer pour obtenir une vue d'ensemble des connexions, des adresses IP et du trafic suspect. Cet outil peut vous aider à identifier plus rapidement les échanges FTP compromis.



⚠ Avertissement

Le protocole FTP est aujourd'hui considéré comme obsolète pour les transferts sensibles. Les alternatives modernes comme SFTP (SSH File Transfer Protocol) ou FTPS (FTP over SSL/TLS) offrent un chiffrement des données et sont fortement recommandées pour les transferts de fichiers sécurisés.

2.8. Mission n°5 : Analyse d'une machine compromise

Le pire est arrivé ! Le hacker a réussi à exécuter le programme malveillant téléchargé à l'étape précédente. L'ordinateur de la victime est maintenant un "zombie" contrôlé par le hacker. Il se connecte discrètement à un serveur distant pour recevoir des ordres et envoyer des informations volées.

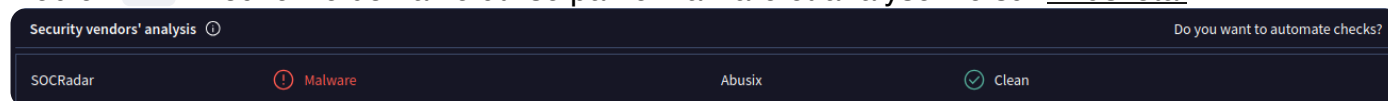
Votre Objectif : C'est une mission d'investigation libre. Analysez le comportement de la machine infectée. Il n'y a pas un seul "flag" à trouver, mais des preuves de l'infection à rassembler.

==> Téléchargez le fichier `infected.pcap` Cette dernière mission est la plus réaliste. Vous êtes dans la peau d'un analyste qui doit comprendre une menace inconnue en se basant uniquement sur ses traces réseau. Bonne chance, détective !

2.8.1. Analyse du trafic réseau

2.8.1.1. Étape 1 : Identification du serveur de commande et contrôle (C2)

? Filtrez sur les requêtes `http` ? Le malware va chercher les instructions du hacker vers un site web en `PHP`. Trouvez le domaine utilisé par le malware et analysez-le sur [VirusTotal](#).



Information

Théorie : Les serveurs C2 Un serveur de commande et contrôle (C2) est un ordinateur central utilisé par les attaquants pour communiquer avec les machines compromises. Il permet de :

- Envoyer des commandes aux machines infectées
- Recevoir les données volées
- Mettre à jour le malware
- Coordonner plusieurs machines zombies (botnet)

2.8.1.2. Étape 2 : Identification du payload malveillant

De plus, le malware va aussi récupérer une archive `jar` juste après avoir contacté le serveur. Cherchez le type `(application/x-msdownload)` dans les informations des paquets suivi du type `(application/java-archive)`

==> Trouvez le paquet malveillant !

Information

Théorie : Les vulnérabilités Java Il s'agit d'un exploit de la vulnérabilité CVE-2012-0507. Cette vulnérabilité critique dans Java permettait l'exécution de code arbitraire à distance. Les vulnérabilités sont classées selon leur gravité :

- **Critique** : Permet l'exécution de code à distance sans authentification
- **Élevée** : Impact majeur mais nécessite des conditions spécifiques
- **Moyenne** : Impact limité ou nécessite des conditions complexes
- **Basse** : Impact minimal sur la sécurité

2.9. Et les VPN dans tout ça ?

Face à la robustesse du chiffrement HTTPS aujourd'hui, l'utilisation d'un VPN est-elle encore pertinente ?



Pour une navigation quotidienne sur des sites connus, on peut considérer qu'un VPN n'est pas forcément nécessaire. Le protocole HTTPS fait déjà un excellent travail pour chiffrer les données échangées, comme vos identifiants ou vos messages, les rendant illisibles pour un espion sur le réseau.

Cependant, cette protection a ses limites. Sur un réseau public ou non maîtrisé comme celui de notre exemple chez McDonald's, le HTTPS n'empêche pas un attaquant de voir la liste des sites que vous visitez. Ces informations, bien que partielles, peuvent suffire à dresser un profil de vos activités.

C'est précisément là que le VPN (Réseau Privé Virtuel) est décisif. Il agit comme un tunnel sécurisé pour votre connexion : votre trafic est chiffré et passe par un serveur distant, le rendant intraquable pour le pirate sur Wireshark.

2.10. Récapitulatif

Félicitations ! Vous avez découvert les bases de la sécurité réseau à travers plusieurs challenges :

1. Analyse de trafic réseau

- Utilisation de Wireshark pour capturer et analyser le trafic
- Compréhension des protocoles HTTP et HTTPS
- Identification des vulnérabilités dans les communications non sécurisées

2. Protection des données sensibles

- Importance du chiffrement HTTPS pour les communications
- Risques liés aux protocoles non sécurisés (HTTP, FTP)
- Bonnes pratiques pour la transmission de données sensibles

3. Détection d'intrusions

- Identification des connexions suspectes
- Analyse des serveurs de commande et contrôle (C2)
- Détection des malwares et des comportements anormaux

4. Bonnes pratiques de sécurité

- Utilisation systématique de HTTPS pour les sites web
- Éviter les réseaux WiFi publics non sécurisés
- Utilisation de VPN pour chiffrer le trafic
- Protection des clés de session et des certificats

5. Outils et techniques

- Maîtrise de Wireshark pour l'analyse de trafic
- Utilisation de filtres pour cibler l'analyse
- Décodage de trafic chiffré avec les clés appropriées
- Analyse des métadonnées et des en-têtes de paquets

Ces connaissances constituent une base solide pour comprendre les vulnérabilités réseau et se protéger contre les attaques courantes !



3. STÉGANOGRAPHIE

3. STÉGANOGRAPHIE

3.1. Introduction

3.1.1. L'Art de Cacher l'Invisible

Aujourd'hui, nous allons explorer un domaine fascinant de la cybersécurité : la stéganographie ! Ce terme, d'origine grecque (steganos signifiant "caché" et graphein "écrire"), désigne l'art et la science de dissimuler des informations dans d'autres supports de données. Contrairement à la cryptographie qui rend un message incompréhensible, la stéganographie le rend invisible.



3.2. Objectifs du chapitre

À la fin de cette journée, vous serez capable de :

1. Comprendre les principes fondamentaux de la stéganographie
2. Analyser et extraire des informations cachées dans des documents PDF
3. Examiner et interpréter les métadonnées d'images (EXIF, IPTC, XMP)
4. Utiliser des outils spécialisés comme AperiSolve et StegOnline
5. Appliquer des techniques de stéganographie avancée (LSB, manipulation colorimétrique)
6. Extraire des fichiers cachés dans des images
7. Décoder des messages encodés (Morse, etc.)
8. Appliquer les bonnes pratiques de sécurité pour la protection des données

3.2.1. Concept et Applications

Imaginez que vous souhaitez transmettre un message confidentiel à un ami. Au lieu de l'écrire directement sur une feuille de papier, vous le dissimulez dans un dessin que vous lui offrez. Pour un observateur non averti, il ne s'agit que d'un simple dessin. Cependant, votre ami, connaissant la technique utilisée, peut extraire le message caché.

En cybersécurité, la stéganographie trouve de nombreuses applications :

- Protection d'informations sensibles sans attirer l'attention
- Communication secrète entre parties
- Marquage numérique (watermarking) pour prouver l'authenticité d'un fichier
- Protection contre la censure dans certains pays

3.2.2. Supports et Techniques

Les supports utilisés pour la stéganographie sont variés :

- Images (JPG, PNG, BMP)
- Documents (PDF, DOC)
- Fichiers audio (MP3, WAV)
- Vidéos (MP4, AVI)
- Textes (en modifiant les espaces ou la ponctuation)

3.2.3. Outils et Méthodes

Pour ce chapitre de découverte de la stéganographie, nous nous concentrerons sur l'analyse de fichiers PDF et d'images. Vous aurez besoin de deux outils web essentiels :

1. **AperiSolve** (<https://www.aperisolve.com/>)

- Outil automatisé d'extraction d'informations
- Analyse des métadonnées (auteur, date, etc.)
- Détection de fichiers cachés
- Extraction de chaînes de caractères

2. **StegOnline** (<https://georgeom.net/StegOnline/upload>)

- Outil spécialisé en stéganographie
- Analyse colorimétrique des images
- Manipulation des bits de poids faible (LSB)
- Visualisation des modifications de pixels

Pour les challenges vous aurez besoin de 2 outils web:

La stéganographie repose sur plusieurs principes fondamentaux :

- **Invisibilité** : Les modifications doivent être imperceptibles
- **Capacité** : Quantité d'information pouvant être cachée
- **Robustesse** : Résistance aux modifications accidentelles
- **Sécurité** : Protection contre la détection

Ces concepts seront illustrés à travers les différents challenges proposés.

3.3. Challenge 1 Carré blanc sur fond blanc

Assets: Chall1.pdf

Ce challenge est une initiation à la stéganographie simple dans les documents PDF. Le titre est un indice crucial : "Carré blanc sur fond blanc" suggère que le contenu est masqué par des nuances de blanc.

3.3.1. Étapes à suivre :

1. Ouvrir le fichier PDF

- Utilisez un lecteur de PDF (Adobe Acrobat Reader, Foxit Reader, visionneuse de votre navigateur, etc.)
- À première vue, le document semble vide - une simple page blanche
- C'est normal, c'est le "carré blanc sur fond blanc" !

2. L'indice crucial : Sélectionner le texte

- Le saviez-vous ? On peut sélectionner tout le texte d'un PDF avec Ctrl + A (ou Cmd + A sur macOS)

Alors ? Ou se trouve finalement le flag ?

3.4. Challenge 2 Linux > Windows

Assets: Chall2.jpg

3.4.0.1. Comprendre les Métadonnées d'une Image

Les images numériques (comme les fichiers JPG, PNG, TIFF, etc.) contiennent souvent, en plus des données visuelles de l'image elle-même, des informations supplémentaires appelées métadonnées. Ces métadonnées sont stockées dans différents formats selon le type de fichier :

- **EXIF** (Exchangeable Image File Format) : Format le plus courant pour les photos numériques
- **IPTC** (International Press Telecommunications Council) : Standard utilisé principalement par les photographes professionnels
- **XMP** (Extensible Metadata Platform) : Format moderne développé par Adobe

Ces métadonnées peuvent inclure :

- Des informations techniques sur la photo (date et heure de prise de vue, modèle de l'appareil photo, réglages d'exposition, flash, résolution)
- Des informations de localisation (coordonnées GPS)
- Des informations sur l'auteur ou le logiciel utilisé pour créer/modifier l'image
- Des commentaires ou des données arbitraires ajoutées par l'utilisateur ou un programme

? Avec le bon outil, on peut même voir le réglage de l'appareil photo ! **?** C'est exactement ce que nous allons faire.

3.4.0.2. Outils pour visualiser les métadonnées

Il existe plusieurs façons d'extraire les métadonnées d'une image :

1. Outils en ligne :

- aperisolve.com
- exif.tools
- metapicz.com
- exifdata.com

2. Logiciels de bureau :

- ExifTool (en ligne de commande)
- GIMP (interface graphique)
- Adobe Photoshop
- Windows : Propriétés de l'image > Détails

3.4.0.3. Méthodologie pour ce challenge

Pour résoudre ce challenge :

1. Utilisez l'image Chall2.jpg
2. Utilisez l'un des outils mentionnés ci-dessus pour extraire les métadonnées
3. Parcourez attentivement toutes les informations affichées
4. Recherchez particulièrement :
 - Les champs de type "Commentaire", "Description", "Auteur", "Logiciel"
 - Les champs non standard qui pourraient contenir du texte arbitraire
 - Les champs qui ne correspondent pas aux informations techniques habituelles d'une photo

Le flag sera probablement une chaîne de caractères qui ne correspond pas aux informations standard d'une photo...

Information

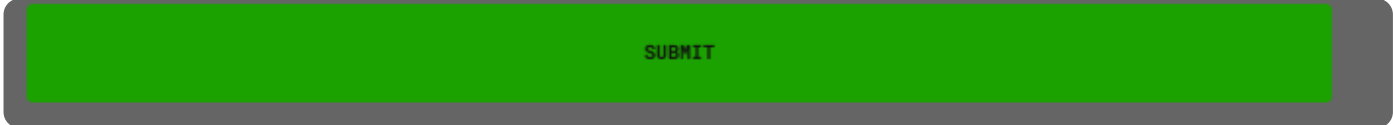
Conseil de sécurité : Lorsque vous partagez des photos en ligne, pensez à supprimer les métadonnées sensibles (comme les coordonnées GPS) pour protéger votre vie privée.

3.5. Challenge 3 La NSA

Assets: Chall3.jpg

Edward Snowden* vous a envoyé une photo contenant un dernier leak de la NSA. Dans cette photo, vous devez le trouver et le révéler au monde entier. Fouillez attentivement et vous le découvrirez.

Pour résoudre ce challenge, vous devez utiliser le site AperiSolve :



Soumettez la photo de Snowden sur le site.

Ensuite, dirigez-vous vers la section "Strings".

L'outil "strings" est un logiciel de stéganographie qui permet de rechercher et d'extraire du texte caché dans des fichiers. Il affiche toutes les chaînes de caractères lisibles trouvées à l'intérieur d'un fichier, comme une image ou un document. Cet outil est fréquemment utilisé dans les défis de cybersécurité pour découvrir des messages ou des informations dissimulées.

Information

Rappel : Nous avons déjà utilisé ensemble la fonction de recherche (CTRL + F) dans un contexte similaire.

3.6. Challenge 4 La plus belle ville du monde

Assets: Chall4.png

Dans ce challenge, l'objectif est de jouer avec la colorimétrie de l'image pour afficher le flag. Les deux sites mentionnés en introduction vous permettront de réussir ce challenge.

La colorimétrie explique comment les couleurs sont représentées numériquement. Pour les images, on utilise souvent le modèle RVB (Rouge, Vert, Bleu), où chaque pixel est une combinaison de ces trois couleurs.

Chaque composante de couleur (R, V, B) est définie par des bits. Les Bits de Poids Faible (LSB - Least Significant Bits) sont les moins importants et leur modification n'altère presque pas la couleur visible. La stéganographie exploite cette propriété pour cacher des informations, comme un "flag", dans l'image en modifiant ces LSB sans que cela soit perceptible à l'œil nu.

Pour résoudre ce challenge, vous devez utiliser le site "<https://georgeom.net/StegOnline/image>". Après avoir uploadé l'image, sélectionnez le paramètre "LSB HALF". En observant attentivement l'image résultante, vous découvrirez le flag.

Bonne chance !

3.7. Challenge 5 Pilule bleu, pilule rouge

Assets: Chall5.png

Neo a caché un fichier dans son image. Cette technique permet d'envoyer des données en toute discrétion. Vous pouvez récupérer ces informations en utilisant l'un des sites mentionnés dans l'introduction.

Information

Le taux de compression ZIP* est généralement d'environ 50%.

What is this ?

Aperi'Solve is an online platform which performs layer analysis on image. The platform also uses zsteg, steghide, outguess, exiftool, binwalk, foremost and strings for deeper steganography analysis. The platform supports the following images format: .png, .jpg, .gif, .bmp, .jpeg, .jfif, .jpe, .tiff...



chall5.png

SUBMIT

Pour résoudre ce challenge, vous devez utiliser AperiSolve et cliquer sur le bouton "Submit". Lorsque vous soumettez l'image, AperiSolve exécute plusieurs scripts et programmes d'analyse, dont "Binwalk" qui nous intéresse particulièrement ici.

Binwalk est un outil en ligne de commande utilisé pour analyser et extraire des fichiers ou des données intégrés dans des images binaires, comme les firmwares. Il permet d'identifier rapidement les fichiers embarqués, les scripts ou les partitions, facilitant ainsi la rétro-ingénierie et la sécurité des systèmes embarqués.

DECIMAL	HEXADECIMAL	DESCRIPTION
0	0x0	PNG image, 1280 x 720, 8-bit/color RGBA, non-interlaced
722	0x2D2	Zlib compressed data, compressed
WARNING:	Extractor.execute	failed to run external extractor 'jar xvf '%e': [Errno 2] No such file or directory: 'jar', 'jar xvf '%e'' might not be installed correctly
1079643	0x10795B	Zip archive data, at least v2.0 to extract, name: en leger.txt
1079743	0x1079BF	End of Zip archive, footer length: 22
1079765	0x1079D5	PNG image, 1280 x 720, 8-bit/color RGBA, non-interlaced
1080487	0x107CA7	Zlib compressed data, compressed
2159408	0x20F330	Zip archive data, at least v2.0 to extract, compressed size: 16, uncompressed size: 16, name: flag.txt
2159516	0x20F39C	End of Zip archive, footer length: 22
DOWNLOAD FILES		

Téléchargez tous les fichiers extraits et vous trouverez le flag à l'intérieur.

3.8. Challenge 6 Gulfstream

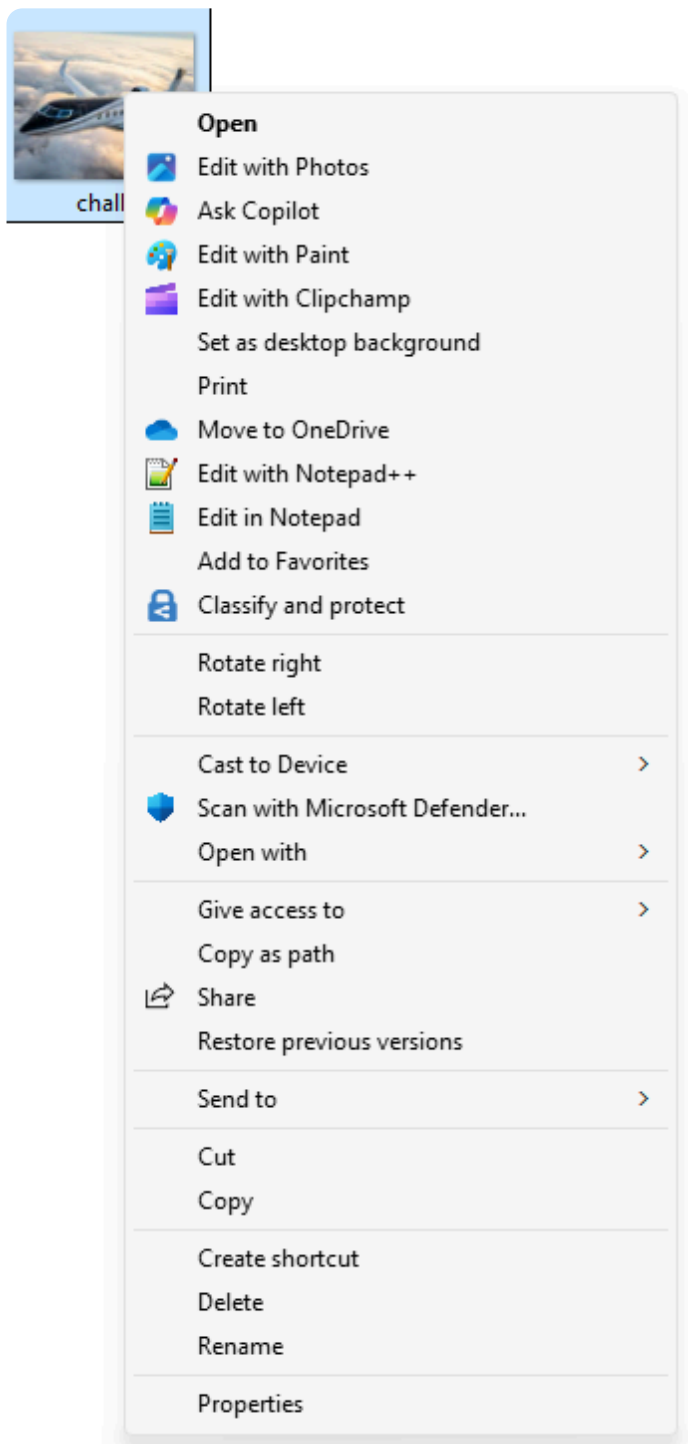
Assets: Chall6.png

Ce challenge se déroule en deux étapes : vous devrez d'abord extraire un code caché dans les métadonnées de l'image, puis le décoder.

Les métadonnées d'une image contiennent des informations essentielles telles que :

- La taille du fichier
- Le format
- La date de création
- Les détails techniques (résolution, profondeur de couleur)
- Les commentaires et annotations

Pour accéder à ces informations, suivez la manipulation suivante :



Vous découvrirez quelque part une séquence de caractères composée de points (.) et de tirets (-). Il s'agit d'un message encodé en code Morse.

Pour décoder ce message, vous avez deux options :

1. Utiliser un tableau de correspondance Morse
2. Utiliser l'outil en ligne suivant : <https://www.dcode.fr/code-morse>

Information

Le code Morse est un système de codage qui utilise des signaux sonores ou lumineux sous forme de points et de tirets pour représenter des lettres, des chiffres et des caractères spéciaux. Il a été développé par Samuel Morse dans les années 1830 pour la télégraphie.

3.9. Challenge 7 Pour aller plus loin...

Assets: chall7.png

Pour venir à bout de ce challenge bonus, vous allez devoir utiliser toutes les choses apprises aujourd'hui.

Ne jamais s'arrêter de chercher, et toujours continuer à apprendre... Une compétence clé en cybersécurité.



3.10. Récapitulatif

Félicitations ! Vous avez découvert les bases de la stéganographie à travers plusieurs challenges :

1. Analyse de documents PDF

- Découverte de texte masqué par des nuances de couleur
- Utilisation de la sélection de texte pour révéler des informations cachées
- Compréhension des limites de la sécurité basée sur le masquage visuel

2. Analyse des métadonnées d'images

- Extraction des informations EXIF, IPTC et XMP
- Identification des données sensibles dans les métadonnées
- Bonnes pratiques pour la protection de la vie privée

3. Techniques de stéganographie avancée

- Manipulation des bits de poids faible (LSB)
- Analyse colorimétrique des images
- Extraction de fichiers cachés dans des images

4. Outils et méthodes d'analyse

- Utilisation d'AperiSolve pour l'analyse automatisée
- Manipulation des images avec StegOnline
- Extraction de chaînes de caractères avec l'outil "strings"

5. Bonnes pratiques de sécurité

- Suppression des métadonnées sensibles avant le partage d'images
- Vérification des fichiers pour détecter des contenus cachés
- Utilisation d'outils spécialisés pour l'analyse de sécurité

Ces connaissances constituent une base solide pour comprendre les techniques de dissimulation d'informations et les méthodes pour les détecter !

3.11. Glossaire

- ZIP : Format de fichier compressé permettant de réduire la taille des fichiers et de les regrouper en une archive unique.
- Flag : Chaîne de caractères qui sert de preuve de réussite dans un challenge de cybersécurité (équivalent du "drapeau" en anglais).
- Edward Snowden : Ancien consultant de la NSA qui a révélé en 2013 l'existence de programmes de surveillance de masse menés par les agences de renseignement américaines.
- Colorimétrie : Science qui étudie la mesure et la quantification des couleurs, permettant de les décrire de manière objective et reproductible.

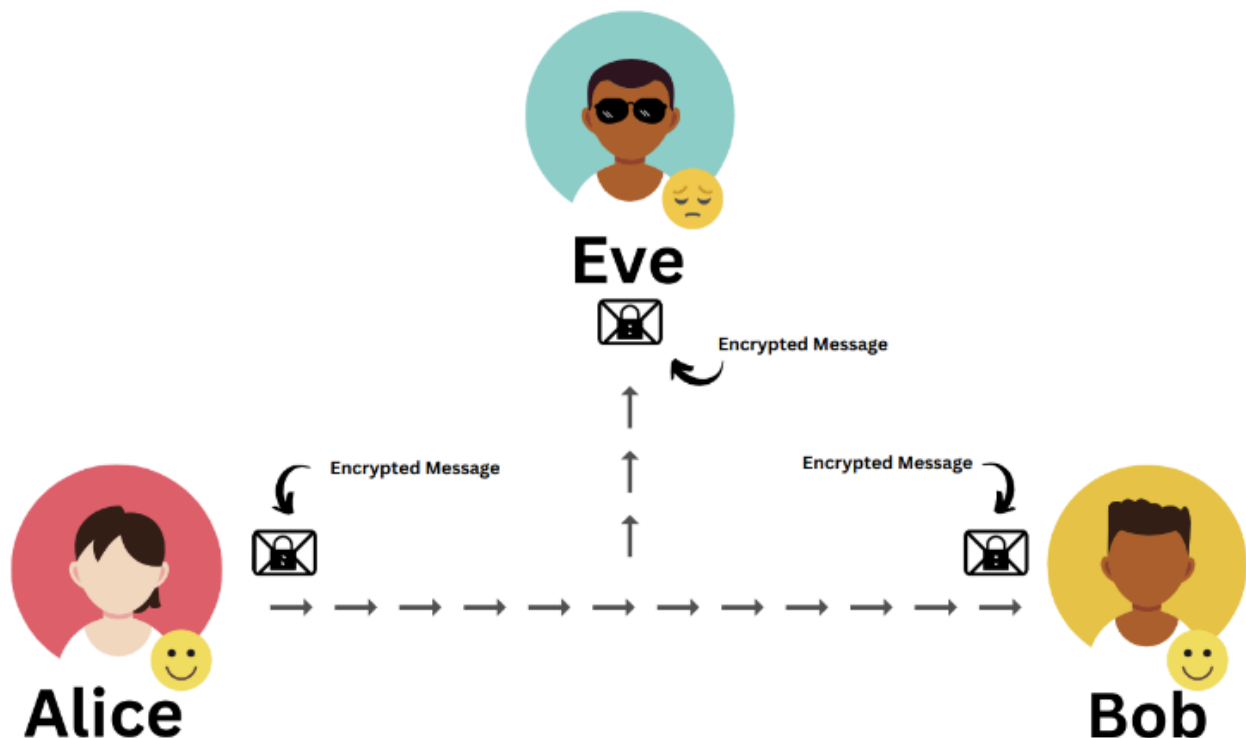


4. CRYPTOGRAPHIE

4. CRYPTOGRAPHIE

4.1. Introduction

Nous allons maintenant explorer un autre pilier essentiel de la cybersécurité : **la cryptographie** ! Le mot "cryptographie" vient du grec "kryptos" (caché) et "graphein" (écrire). C'est donc littéralement l'art d'écrire de manière cachée, ou plus précisément, de transformer des informations pour les rendre illisibles aux personnes non autorisées.



Pour comprendre la cryptographie, on utilise souvent une histoire avec trois personnages : **Alice, Bob et Ève**.

1. Alice souhaite envoyer un message secret à Bob.
2. Pour que personne d'autre ne puisse le lire, Alice utilise la cryptographie pour chiffrer son message. Elle le transforme en un code incompréhensible.
3. Bob, qui possède la clé de déchiffrement, peut alors décoder le message et le lire.
4. Ève, c'est l'espionne ! Elle tente d'intercepter le message d'Alice à Bob pour le lire, mais grâce à la cryptographie, elle ne voit qu'un charabia incompréhensible.

La cryptographie est omniprésente dans notre monde numérique :

- Pour sécuriser les communications sur Internet (lorsque vous voyez "https://" et le petit cadenas dans la barre d'adresse).
- Pour protéger les mots de passe stockés dans les bases de données.
- Pour signer numériquement des documents et garantir leur authenticité.
- Pour chiffrer des données sur votre ordinateur ou votre téléphone et empêcher qu'elles soient lues en cas de vol.

Il existe de nombreuses méthodes de chiffrement, des plus simples (comme le code César, où l'on décale les lettres) aux plus complexes (utilisées par les banques et les gouvernements). Nous allons explorer quelques-unes de ces méthodes dans les challenges d'aujourd'hui.

Pour vous aider dans ces challenges, voici deux outils en ligne recommandés pour le chiffrement et le déchiffrement :

- <https://www.dcode.fr/>
- <https://gchq.github.io/CyberChef/>

4.2. Objectifs du chapitre

À la fin de cette journée, vous serez capable de :

1. Comprendre et appliquer les principes fondamentaux de la cryptographie
2. Utiliser le chiffrement César et ses variantes (ROT13)
3. Maîtriser l'encodage et le décodage Base64
4. Décoder des messages en braille
5. Convertir entre différents systèmes de numération (décimal, hexadécimal)
6. Utiliser des outils en ligne comme CyberChef et dcode.fr
7. Appliquer plusieurs algorithmes de décodage en séquence
8. Comprendre la différence entre chiffrement et encodage

4.3. Challenge 1 : Irréductible gaulois

Chaine de caractères : "IODJ Dvwhula hw Rehola"

Pour ce challenge, vous allez devoir utiliser un algorithme de chiffrement qui date de plus de 2000 ans. Vous pouvez même trouver la solution avec une feuille et un stylo.

Le chiffrement César est une méthode historique pour cacher un message. Il consiste à décaler chaque lettre de l'alphabet d'un certain nombre de places. Par exemple, avec un décalage de 3, A devient D, B devient E, etc. Ce système est très simple et facile à comprendre. Aujourd'hui, il n'est plus utilisé pour la sécurité, mais il reste un excellent outil pédagogique pour apprendre les bases du chiffrement.

Essayez différents décalages !

4.4. Challenge 2 Capitale de la gastronomie

Chaine de caractères : RkxBR3tQQVVMX0JPQ1VTRX0=

Pour ce challenge, vous allez devoir décoder le flag plutôt que le déchiffrer. Les algorithmes de chiffrement et l'encodage sont deux concepts différents. Sur CyberChef ou dcode.fr, vous pouvez tester différentes méthodes jusqu'à trouver la bonne.

Information

Vous devez utiliser le Base64 pour décoder ce flag.

Le Base64 est un système d'encodage qui transforme des données binaires en une suite de caractères alphanumériques (A-Z, a-z, 0-9, + et /). Il est principalement utilisé pour rendre les données compatibles avec des systèmes qui ne supportent que du texte ASCII, comme les emails ou les pages web. Contrairement au chiffrement, le Base64 n'est pas une méthode de protection des données, mais simplement un moyen de les transporter de manière fiable.

Information

L'hexadécimal est un système de numération en base 16, utilisant les chiffres de 0 à 9 et les lettres A à F pour représenter les valeurs. Il est largement utilisé en informatique pour représenter les adresses mémoire, les couleurs ou les données binaires de manière plus concise et lisible.

Les algorithmes ci-dessus sont les 3 algorithmes à utiliser. Vous devez les appliquer dans le bon ordre pour décoder le message.

4.7. Challenge 5 Alpha Wann

Chaine de caractères : "6 12 1 7 19 21 16 9 14 6 15"

La table ASCII (American Standard Code for Information Interchange) est un standard qui associe des valeurs numériques à des caractères alphanumériques, symboles et commandes de contrôle, permettant la communication entre les dispositifs informatiques. Elle utilise 7 bits, ce qui permet de représenter 128 caractères différents (de 0 à 127), facilitant ainsi l'échange d'informations entre logiciels et matériels.

Dans ce challenge, vous allez devoir utiliser une correspondance simple entre les lettres de l'alphabet et leur position : A=1, B=2, C=3, etc. jusqu'à Z=26.

Pour vous aider à démarrer, voici la première : 6 = F.

Votre mission est de décoder la suite de nombres pour découvrir le message caché.

4.8. Challenge 7 Pour aller plus loin...

Pour venir à bout de ce challenge bonus, vous allez devoir utiliser toutes les choses apprises aujourd'hui.

Si vous avez pu comprendre le concept de hash, retrouvez la clé !

```
f144a6907dc4284d1f9fe6a7d9b9ff53c02c1d07ba68fk24d413d7ff7f757a782
```

4.9. Récapitulatif

Félicitations ! Vous avez découvert les bases de la cryptographie à travers plusieurs challenges :

1. Chiffrement classique

- Compréhension du chiffrement César et ses variantes
- Utilisation de la rotation de caractères (ROT13)
- Découverte des limites des chiffrements simples

2. Encodage et décodage

- Utilisation du Base64 pour l'encodage de données
- Compréhension de la différence entre chiffrement et encodage
- Manipulation des données binaires en format texte

3. Systèmes de codage spéciaux

- Découverte du code Braille et son utilisation
- Manipulation des valeurs hexadécimales
- Conversion entre différents systèmes de numération

4. Outils et méthodes

- Utilisation de CyberChef et dcode.fr
- Application de plusieurs algorithmes en séquence
- Décodage de messages complexes

5. Bonnes pratiques de sécurité

- Importance du chiffrement pour protéger les données sensibles
- Compréhension des limites des chiffrements simples
- Utilisation d'outils appropriés pour le chiffrement/déchiffrement

Ces connaissances constituent une base solide pour comprendre les principes fondamentaux de la cryptographie et leur application dans la sécurité informatique !

4.10. Glossaire

- On dit chiffrer: <https://chiffrer.info/>



5. MISC

5. MISC

En cybersécurité, surtout dans les compétitions CTF, vous tomberez souvent sur une catégorie un peu particulière : **MISC** (pour "Miscellaneous", ce qui signifie "divers" ou "varié" en anglais).

C'est un peu la boîte à surprises des défis ! Si un challenge ne rentre pas clairement dans les catégories Web, Réseau, Cryptographie ou Stéganographie, il y a de fortes chances qu'il atterrisse dans MISC.

5.1. Objectifs du chapitre

À la fin de cette journée, vous serez capable de :

1. Comprendre et manipuler les QR codes, y compris leur structure et leur complétion
2. Analyser des dumps mémoire pour identifier des fichiers cachés et des traces d'attaques
3. Pratiquer le GEOINT (Intelligence Géospatiale) pour localiser des lieux à partir d'images
4. Manipuler des fichiers audio (inversion temporelle, modification du pitch)
5. Utiliser des outils en ligne pour le décodage et la manipulation de données
6. Comprendre les différentes méthodes de dissimulation d'informations

5.2. QRcode

Assets: incomplete_qr.png

Un mystérieux QR code est apparu... Sauriez-vous retrouver le flag à partir de cette image ?



Voici à quoi ressemble un QR code standard :



Un QR code (Quick Response code) est un code-barres matriciel bidimensionnel qui peut stocker diverses informations comme des URL, du texte ou des données de contact. Son fonctionnement repose sur le scan par un smartphone ou un lecteur spécialisé, permettant de décoder instantanément l'information qu'il contient. Une fois scanné, il peut rediriger vers une page web, une application ou afficher directement le contenu stocké.

Pour ce challenge, vous devrez compléter le QR code incomplet en y ajoutant les éléments manquants à l'aide d'un logiciel de retouche d'image comme Paint ou un autre outil similaire, puis le scanner pour découvrir le flag.

5.3. Houston

Assets: challenge houston/audio.wav

Nous venons de récupérer un message audio de la station spatiale. Malheureusement, il est inaudible. À vous de retrouver le flag secret !

Toute donnée, qu'il s'agisse d'un texte, d'une vidéo ou d'un fichier audio comme dans notre cas, peut cacher un message à l'intérieur. Dans ce challenge, le message n'est pas dissimulé de manière discrète car il est présent en clair.

Habituellement, on utilise un son d'une musique ou d'une interview et, avec les bons réglages audio (par exemple en supprimant les notes aiguës ou en modifiant certaines fréquences), on découvre un message caché. Dans notre cas, la séquence est en code Morse.

Le code Morse est un système de codage qui utilise des signaux sonores ou lumineux sous forme de points et de tirets pour représenter des lettres, des chiffres et des caractères spéciaux. Il a été principalement utilisé pour la communication longue distance, notamment dans la télégraphie, permettant d'envoyer des messages codés rapidement et efficacement.

Pour décoder le message, utilisez ce site : <https://morsecode.world/international/decoder/audio-decoder-adaptive.html>

Information

Le code Morse utilise deux types de signaux :

- Un point (.) : signal court
- Un tiret (-) : signal long (environ trois fois plus long qu'un point) Les espaces entre les signaux permettent de distinguer les caractères et les mots.

5.4. Three

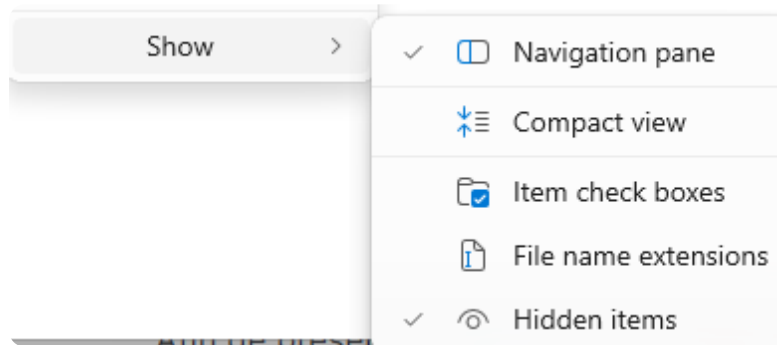
Assets: challenge three

Nous avons mis la main sur un ordinateur infecté par un malware très virulent. Afin de préserver l'intégrité des preuves, nous avons réalisé une copie de la mémoire de l'appareil. Votre mission est d'analyser ce dump mémoire pour identifier les traces de l'attaquant.

Un dump mémoire est une copie partielle ou totale de la mémoire vive d'une machine, quel que soit son système d'exploitation (Linux, Windows, etc.). Souvent, lors d'une analyse post-incident, on récupère un dump partiel car il est effectué pendant ou après une attaque. L'objectif est de trouver des traces de l'attaquant qui peuvent constituer des indices et nous permettre de remonter jusqu'à lui.

Ce challenge contient **3 flags** à découvrir :

- Un fichier dans le répertoire utilisateur "john"
- Un fichier dans les fichiers système
- Un fichier caché Windows



Option fichier caché : C'est une option de Windows qui permet aux utilisateurs de masquer des fichiers pour qu'ils ne soient pas accessibles de manière malveillante.

5.5. GeoINT

Pour les trois prochains challenges, vous allez analyser des images pour déterminer leur emplacement géographique ou extraire des informations spécifiques.

Le GEOINT (Geospatial Intelligence) désigne l'ensemble des techniques de collecte, d'analyse et de visualisation d'informations géographiques et d'images satellite pour soutenir la prise de décision. Cette discipline permet de surveiller des zones sensibles, d'anticiper des menaces et d'optimiser les opérations militaires ou sécuritaires. Grâce aux avancées technologiques, le GEOINT offre aujourd'hui des données précises et en temps réel, renforçant ainsi la capacité d'intervention et d'analyse des agences de renseignement.

Information

Pour une expérience de recherche authentique et formatrice, nous vous déconseillons d'utiliser Google Lens qui simplifierait excessivement la tâche.

5.6. Voiture sportive



Ce challenge est le premier challenge de GeoINT, ce qui signifie "Intelligence Géospatiale" (INT pour intelligence et GEO pour géographie). Votre objectif est de trouver le nom de la sortie d'autoroute en vous basant sur les informations visibles dans l'image.

5.7. Michael Jordan



Dans ce challenge, vous devez identifier l'emplacement et le nom de cette structure architecturale.

5.8. Asia



Dans ce challenge, vous devez localiser cette ville.

5.9. Mariokart reverse

Assets: Mario Kart Miroir

Pour ce challenge, vous pouvez écouter le son fourni en assets plusieurs fois. Essayez d'identifier ce que vous entendez et recherchez sur Internet ce qui vous semble probable. Si après 15 minutes vous n'avez pas trouvé, lisez le paragraphe suivant.

Ce challenge illustre les concepts de manipulation audio que nous avons abordés dans le challenge du code Morse. Nous avons appliqué deux transformations distinctes au fichier audio :

1. **Modification du pitch** : La voix a été modifiée en augmentant sa fréquence (pitch), ce qui la rend plus aiguë et difficilement reconnaissable. Cette technique est couramment utilisée pour masquer l'identité d'un locuteur.
2. **Inversion temporelle** : Le son a été inversé dans le temps, comme si on le lisait à l'envers. Cette transformation rend le message complètement incompréhensible à l'écoute directe.

Ce site pourrait vous être utile : <https://mp3cut.net/fr/reverse-audio> !

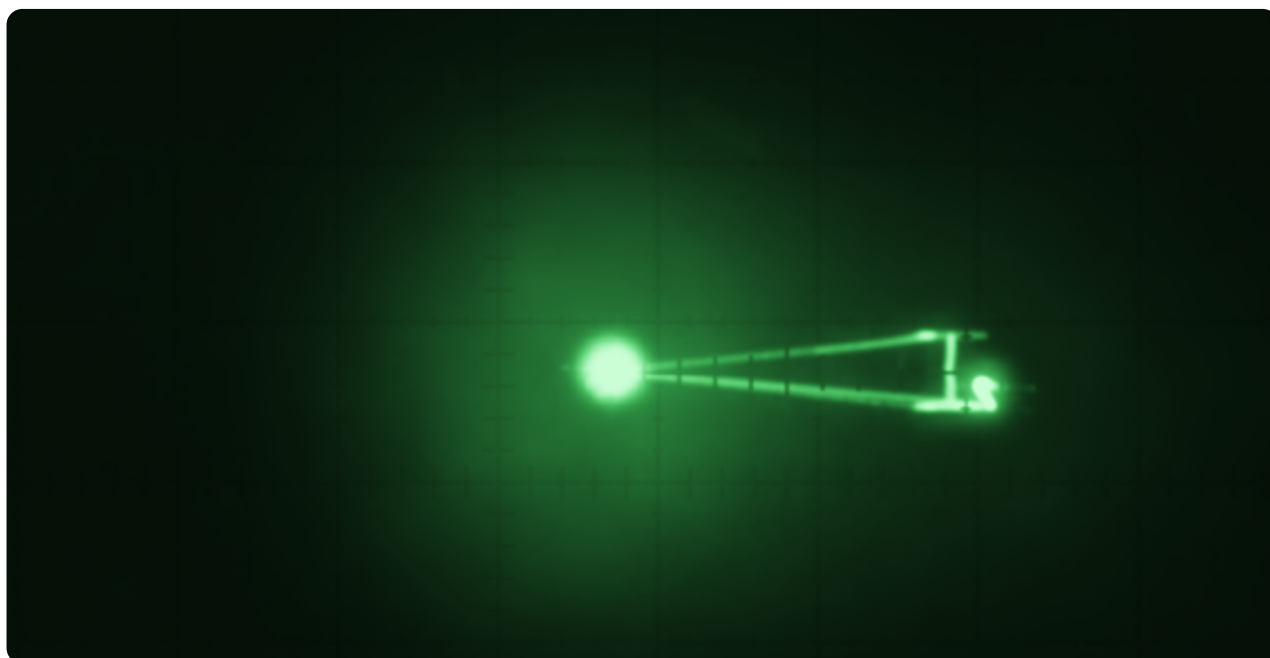
Information

Information technique : La manipulation audio est une technique de stéganographie qui consiste à modifier les caractéristiques d'un signal sonore pour y cacher des informations. Les modifications peuvent affecter la fréquence (pitch), la vitesse, la phase ou l'ordre temporel du signal.

5.10. Challenge 7 Pour aller plus loin...

Assets: chall7.mp3

Pour venir à bout de ce challenge bonus, vous allez devoir utiliser toutes les choses apprises aujourd'hui. Explorez donc les ondes pour retrouver le message caché !



5.11. Récapitulatif

Félicitations ! Vous avez découvert les bases de la catégorie MISC à travers plusieurs challenges :

1. Analyse d'images et de codes

- Manipulation et complétion de QR codes
- Compréhension de la structure des codes-barres matriciels
- Utilisation d'outils de retouche d'image

2. Analyse audio

- Décodage de messages en code Morse
- Manipulation de fichiers audio (inversion, modification du pitch)
- Utilisation d'outils de décodage audio

3. Analyse de mémoire

- Compréhension des dumps mémoire
- Recherche de fichiers cachés
- Analyse de fichiers système et utilisateur

4. Géolocalisation et intelligence géospatiale

- Analyse d'images pour identifier des lieux
- Utilisation d'indices visuels pour la géolocalisation
- Compréhension des concepts de GEOINT

5. Bonnes pratiques de sécurité

- Vérification des fichiers audio suspects
- Analyse approfondie des images et métadonnées
- Utilisation d'outils spécialisés pour chaque type d'analyse

Ces connaissances constituent une base solide pour comprendre les défis MISC et développer une approche méthodique pour résoudre des problèmes variés en cybersécurité !

6. Conclusion

Au terme de cette semaine d'initiation à la cybersécurité, vous avez exploré les cinq domaines fondamentaux de la sécurité informatique :

1. **Web** : Vous avez découvert comment les sites web fonctionnent et comment identifier les vulnérabilités courantes, de l'inspection du code source à la manipulation des paramètres d'URL.
2. **Réseau** : Vous avez appris à analyser le trafic réseau avec Wireshark, comprenant l'importance cruciale du chiffrement et les risques liés aux protocoles non sécurisés.
3. **Stéganographie** : Vous avez exploré l'art de dissimuler des informations dans différents supports (images, documents, audio) et les techniques pour les révéler.
4. **Cryptographie** : Vous avez découvert les bases du chiffrement, des méthodes historiques comme le code César aux techniques modernes d'encodage.
5. **MISC** : Vous avez abordé des défis variés qui combinent différentes compétences, de l'analyse d'images à la manipulation audio.

Cette formation pratique vous a permis de développer une approche méthodique pour résoudre des problèmes de sécurité. Vous avez appris à :

- Observer attentivement les détails
- Utiliser les outils appropriés
- Appliquer une démarche logique
- Comprendre les concepts fondamentaux de la sécurité

Nous espérons que cette introduction vous aura donné envie d'approfondir vos connaissances en cybersécurité. Que ce soit pour une carrière professionnelle ou par simple curiosité, les compétences acquises constituent une base solide pour votre parcours dans ce domaine passionnant.

6.1. Pour aller plus loin

Cette introduction à la cybersécurité n'est que le début d'un vaste domaine en constante évolution. Il existe de nombreuses ressources en ligne pour continuer votre apprentissage :

- **OverTheWire Bandit** : Une série de défis progressifs qui vous apprendront les bases de Linux et de la sécurité système. Chaque niveau vous présente de nouveaux concepts et commandes à maîtriser.
- **TryHackMe** : Une plateforme interactive proposant des "rooms" thématiques couvrant tous les aspects de la cybersécurité, du niveau débutant au niveau avancé.
- **HackTheBox** : Des machines virtuelles vulnérables à exploiter, parfaites pour mettre en pratique vos compétences en pentest.
- **Root-Me** : Une plateforme française proposant des défis variés dans différents domaines de la sécurité informatique.

Ces plateformes vous permettront de :

- Renforcer vos compétences en ligne de commande Linux
- Comprendre les mécanismes d'exploitation
- Développer une méthodologie de test d'intrusion
- Apprendre à sécuriser des systèmes

N'hésitez pas à explorer ces ressources et à participer à des CTF (Capture The Flag) pour mettre en pratique vos connaissances dans un contexte ludique et compétitif.